

Chapter 02

2026 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

Windows 서버

1. 계정 관리	177
2. 서비스 관리	196
3. 패치 관리	233
4. 로그 관리	235
5. 보안 관리	241

01 Windows 서버 취약점 분석 · 평가 항목

1. 계정 관리

점검항목	항목 중요도	항목코드
Administrator 계정 이름 변경 등 보안성 강화	상	W-01
Guest 계정 비활성화	상	W-02
불필요한 계정 제거	상	W-03
계정 잠금 임계값 설정	상	W-04
해독 가능한 암호화를 사용하여 암호 저장 해제	상	W-05
관리자 그룹에 최소한의 사용자 포함	상	W-06
Everyone 사용 권한을 익명 사용자에게 적용	중	W-07
계정 잠금 기간 설정	중	W-08
비밀번호 관리정책 설정	상	W-09
마지막 사용자 이름 표시 안 함	중	W-10
로컬 로그인 허용	중	W-11
익명 SID/이름 변환 허용 해제	중	W-12
콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한	중	W-13
원격터미널 접속 가능한 사용자 그룹 제한	중	W-14

2. 서비스 관리

점검항목	항목 중요도	항목코드
사용자 개인키 사용 시 암호 입력	상	W-15
공유 권한 및 사용자 그룹 설정	상	W-16
하드디스크 기본 공유 제거	상	W-17
불필요한 서비스 제거	상	W-18

점검항목	항목 중요도	항목코드
불필요한 IIS 서비스 구동 점검	상	W-19
NetBIOS 바인딩 서비스 구동 점검	상	W-20
암호화되지 않는 FTP 서비스 비활성화	상	W-21
FTP 디렉토리 접근권한 설정	상	W-22
공유 서비스에 대한 익명 접근 제한 설정	상	W-23
FTP 접근 제어 설정	상	W-24
DNS Zone Transfer 설정	상	W-25
RDS(Remote Data Services)제거	상	W-26
최신 Windows OS Build 버전 적용	상	W-27
터미널 서비스 암호화 수준 설정	중	W-28
불필요한 SNMP 서비스 구동 점검	중	W-29
SNMP Community String 복잡성 설정	중	W-30
SNMP Access control 설정	중	W-31
DNS 서비스 구동 점검	중	W-32
HTTP/FTP/SMTP 배너 차단	하	W-33
Telnet 서비스 비활성화	중	W-34
불필요한 ODBC/OLE-DB 데이터 소스와 드라이브 제거	중	W-35
원격터미널 접속 타임아웃 설정	중	W-36
예약된 작업에 의심스러운 명령이 등록되어 있는지 점검	중	W-37

3. 패치 관리

점검항목	항목 중요도	항목코드
주기적 보안 패치 및 벤더 권고사항 적용	상	W-38
백신 프로그램 업데이트	상	W-39

4. 로그 관리

점검항목	항목 중요도	항목코드
정책에 따른 시스템 로깅 설정	중	W-40
NTP 및 시각 동기화 설정	중	W-41
이벤트 로그 관리 설정	하	W-42
이벤트 로그 파일 접근 통제 설정	중	W-43

5. 보안 관리

점검항목	항목 중요도	항목코드
원격으로 액세스할 수 있는 레지스트리 경로	상	W-44
백신 프로그램 설치	상	W-45
SAM 파일 접근 통제 설정	상	W-46
화면보호기 설정	상	W-47
로그온하지 않고 시스템 종료 허용	상	W-48
원격 시스템에서 강제로 시스템 종료	상	W-49
보안 감사를 로그할 수 없는 경우 즉시 시스템 종료	상	W-50
SAM 계정과 공유의 익명 열거 허용 안 함	상	W-51
Autologon 기능 제어	상	W-52
이동식 미디어 포맷 및 꺼내기 허용	상	W-53
Dos공격 방어 레지스트리 설정	중	W-54
사용자가 프린터 드라이버를 설치할 수 없게 함	중	W-55
SMB 세션 중단 관리 설정	중	W-56
로그온 시 경고 메시지 설정	하	W-57
사용자별 홈 디렉터리 권한 설정	중	W-58
LAN Manager 인증 수준	중	W-59
보안 채널 데이터 디지털 암호화 또는 서명	중	W-60

점검항목	항목 중요도	항목코드
파일 및 디렉토리 보호	중	W-61
시작프로그램 목록 분석	중	W-62
도메인 컨트롤러-사용자의 시간 동기화	중	W-63
윈도우 방화벽 설정	중	W-64

02. Windows 서버

W-01 (상)	Windows 서버 > 1. 계정 관리
	Administrator 계정 이름 변경 등 보안성 강화
개요	
점검 내용	윈도우 최상위 관리자 계정인 Administrator의 계정명 변경 또는 보안을 고려한 비밀번호 설정 여부 점검
점검 목적	윈도우 기본 관리자 계정인 Administrator의 이름을 변경 또는 보안을 고려한, 잘 알려진 계정을 통한 악의적인 패스워드 추측 공격을 차단하기 위함
보안 위협	- 일반적으로 관리자 계정으로 잘 알려진 Administrator를 변경하지 않는 경우 악의적인 사용자의 패스워드 추측 공격을 통해 사용 권한 상승의 위험이 있으며, 관리자를 유인하여 침입자의 액세스를 허용하는 악성코드를 실행할 위험이 존재함 - 윈도우 최상위 관리자 계정인 Administrator는 기본적으로 삭제하거나 잠글 수 없어 악의적인 사용자의 목표가 될 위험이 존재함
참고	※ 윈도우 서버는 Administrator 계정을 비활성화할 수 있으나 안전 모드로 컴퓨터를 시작할 경우 본 계정은 자동으로 활성화됨
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : Administrator 기본 계정 이름을 변경하거나 강화된 비밀번호를 적용한 경우
	취약 : Administrator 기본 계정 이름을 변경하지 않거나 단순 비밀번호를 적용한 경우
조치 방법	Administrator 기본 계정 이름 변경 및 보안성이 있는 비밀번호 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 관리 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “계정: Administrator 계정 이름 바꾸기”를 유추하기 어려운 계정 이름으로 변경



[Administrator 계정 이름 변경]

W-02 (상)	Windows 서버 > 1. 계정 관리
	Guest 계정 비활성화
개요	
점검 내용	Guest 계정 비활성화 여부 점검
점검 목적	Guest 계정을 비활성화하여 불특정 다수의 임시적인 시스템 접근을 차단하기 위함
보안 위협	Guest 계정은 시스템에 임시로 액세스해야 하는 사용자용 계정으로, 해당 계정을 사용하여 권한 없는 사용자가 시스템에 익명으로 액세스할 수 있으므로 비인가자 접근, 정보 유출 등 보안 위협이 존재함
참고	※ Windows Guest 계정은 삭제 불가능한 built-in 계정으로 보안 강화 목적으로 반드시 비활성화 처리해야 함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : Guest 계정이 비활성화되어 있는 경우
	취약 : Guest 계정이 활성화되어 있는 경우
조치 방법	Guest 계정 비활성화
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT

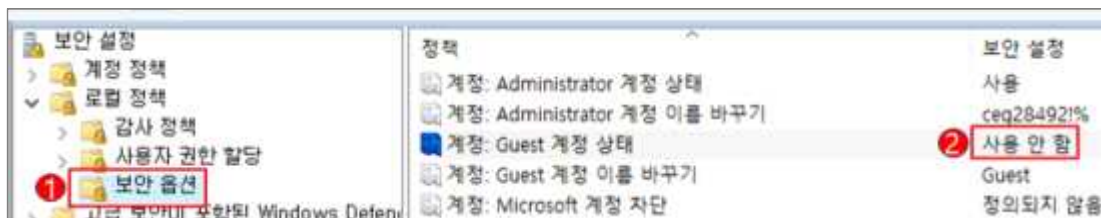
Step 1) 시작 > 프로그램 > 관리 도구 > 도메인 사용자 관리 > Guest 계정 선택 > 등록정보

Step 2) “계정 사용 안 함” 설정

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션 > 계정: Guest 계정 상태

Step 2) 계정 “사용 안 함” 설정



[Guest 계정 상태 사용 안 함 설정]

02. Windows 서버

W-03 (상)	Windows 서버 > 1. 계정 관리
	불필요한 계정 제거
개요	
점검 내용	시스템 내 불필요한 계정 및 의심스러운 계정의 존재 여부를 점검
점검 목적	퇴직, 전직, 휴직 등의 이유로 사용하지 않는 계정, 불필요한 계정 및 의심스러운 계정을 삭제하여, 일반적으로 로그인에 필요치 않은 해당 계정들을 통한 로그인을 차단하고, 계정의 패스워드 추측 공격 시도를 차단하기 위함
보안 위협	관리되지 않은 불필요한 계정은 장기간 비밀번호가 변경되지 않아 무차별 대입 공격(Brute Force Attack)이나 비밀번호 추측 공격>Password Guessing Attack)의 가능성이 존재하며, 또한 이런 공격으로 계정정보가 유출되어도 유출 사실을 인지하기 어려워 초기 대응이 불가능한 위험이 존재함
참고	※ 무차별 대입 공격(Brute Force Attack): 특정 암호를 해독하기 위해 가능한 모든 값을 대입하는 공격 방법
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 불필요한 계정이 존재하지 않는 경우
	취약 : 불필요한 계정이 존재하는 경우
조치 방법	현재 계정 현황 확인 후 불필요한 계정 삭제
조치 시 영향	명확하게 파악되지 않은 계정을 삭제하는 경우 해당 계정과 관련한 업무에 장애 발생 가능성이 존재함

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 프로그램 > 관리 도구 > 도메인 사용자 관리 > 계정 선택 > 등록 정보

Step 2) “계정 사용 안 함” 설정 또는 계정 삭제

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 컴퓨터 관리 > 로컬 사용자 및 그룹 > 사용자

Step 2) 등록된 계정 중 불필요한 사용자 선택 > 속성 > “계정 사용 안 함” 설정 또는 계정 삭제



[사용자 계정 확인]

W-04 (상)	Windows 서버 > 1. 계정 관리
	계정 잠금 임계값 설정
개요	
점검 내용	계정 잠금 임계값의 설정 여부 점검
점검 목적	계정 잠금 임계값을 설정하여 공격자의 자유로운 자동화 암호 유추 공격을 차단하기 위함
보안 위협	공격자는 시스템의 계정 잠금 임계값이 설정되지 않는 경우, 자동화된 방법을 이용하여 모든 사용자 계정에 대해 암호 조합 공격을 자유롭게 시도할 수 있으므로 사용자 계정 정보의 노출 위험이 존재함
참고	※ 계정 잠금 임계값 설정은 사용자 계정이 잠기는 로그인 실패 횟수를 결정하며 잠긴 계정은 관리자가 재설정하거나 해당 계정의 잠금 유지 시간이 만료되어야 사용할 수 있음 ※ 계정 잠금 정책 : 해당 계정이 시스템으로부터 잠기는 환경과 시간을 결정하는 정책으로 '계정 잠금 기간', '계정 잠금 임계값', '다음 시간 후 계정 잠금 수를 원래대로 설정'의 세 가지 하위 정책을 가짐 ※ 관련 점검 항목: W-08(중)
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 계정 잠금 임계값이 5 이하의 값으로 설정된 경우
	취약 : 계정 잠금 임계값이 5 초과인 값으로 설정된 경우
조치 방법	계정 잠금 임계값을 5 이하의 값으로 설정
조치 시 영향	Administrator 계정은 잠기지 않으며, 일반 계정의 경우 5회 패스워드 입력 실패 시 잠김

점검 및 조치 사례

● Window NT

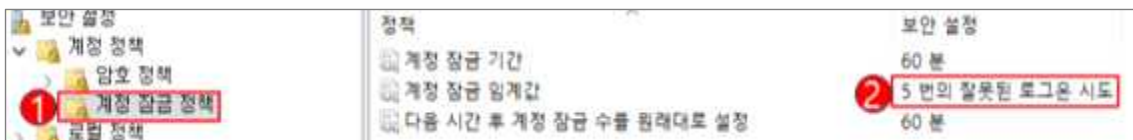
Step 1) 시작 > 프로그램 > 관리 도구 > 도메인 사용자 관리자 > 정책 > 계정 정책

Step 2) “계정 잠금” 선택 후 “잠금”에 “5” 이하의 값 설정

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 계정 정책 > 계정 잠금 정책

Step 2) “계정 잠금 임계값”을 “5” 이하의 값으로 설정



[계정 잠금 임계값 설정]

02. Windows 서버

W-05 (상)	Windows 서버 > 1. 계정 관리
	해독 가능한 암호화를 사용하여 암호 저장 해제
개요	
점검 내용	해독 가능한 암호화 사용 여부 점검
점검 목적	“해독 가능한 암호화를 사용하여 암호 저장” 정책이 설정되어 사용자 계정 비밀번호가 해독 가능한 텍스트 형태로 저장되는 것을 차단하기 위함
보안 위협	위 정책이 설정된 경우 운영체제에서 사용자 계정, 비밀번호를 입력받아 인증을 진행하는 응용 프로그램 프로토콜 지원 시 운영체제는 사용자의 비밀번호를 해독 가능한 방식으로 저장하기 때문에, 노출된 계정에 대해 공격자가 비밀번호 복호화 공격으로 비밀번호를 획득하여 네트워크 리소스에 접근할 위험이 존재함
참고	※ “해독 가능한 암호화를 사용하여 암호 저장” 정책은 암호를 암호화하지 않은 상태로 저장하여 일반 텍스트 버전의 암호를 저장하는 것과 같으나 시스템에서 기본적으로 동작하지는 않음
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “해독 가능한 암호화를 사용하여 암호 저장” 정책이 “사용 안 함”으로 설정된 경우
	취약 : “해독 가능한 암호화를 사용하여 암호 저장” 정책이 “사용”으로 설정된 경우
조치 방법	“해독 가능한 암호화를 사용하여 암호 저장”을 “사용 안 함”으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Window NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 계정 정책 > 암호 정책

Step 2) “해독 가능한 암호화를 사용하여 암호 저장”을 “사용 안 함”으로 설정



[해독 가능한 암호화를 사용하여 암호 저장 정책 설정]

W-06 (상)	Windows 서버 > 1. 계정 관리
	관리자 그룹에 최소한의 사용자 포함
개요	
점검 내용	관리자 그룹에 불필요한 사용자의 포함 여부 점검
점검 목적	관리자 그룹 구성원에 불필요한 사용자의 포함 여부를 점검하여, 관리 권한 사용자를 최소화하고자 함
보안 위협	Administrators와 같은 관리자 그룹에 속한 구성원은 컴퓨터 시스템에 대한 완전하고 제한 없는 액세스 권한을 가지므로, 사용자를 관리자 그룹에 포함하면 비인가 사용자에게 과도한 관리 권한이 부여되어 내부 정보 유출 위험이 존재함
참고	※ 관리 권한의 오남용으로 인한 시스템 피해를 줄이기 위해서 관리 업무를 위한 계정과 일반 업무를 위한 계정을 분리하여 사용하는 것이 바람직함 ※ 시스템 관리를 위해서 관리 권한 계정과 일반 권한 계정을 분리하여 운영하는 것을 권고 ※ 시스템 관리자는 원칙적으로 1명 이하로 유지하고, 부득이하게 2명 이상의 관리 권한자를 유지해야 할 경우, 관리자 그룹에는 최소한의 사용자만 포함하도록 해야 함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : Administrators 그룹의 구성원을 1명 이하로 유지하거나, 불필요한 관리자 계정이 존재하지 않는 경우
	취약 : Administrators 그룹에 불필요한 관리자 계정이 존재하는 경우
조치 방법	Administrators 그룹에 포함된 불필요한 계정 제거
조치 시 영향	Administrator 그룹에 있는 계정을 잘못 삭제하는 경우 해당 업무에 장애 발생 가능성이 있음

점검 및 조치 사례

● Window NT

Step 1) 시작 > 프로그램 > 관리 도구 > 도메인 사용자 관리 > Administrators 그룹 > 등록 정보

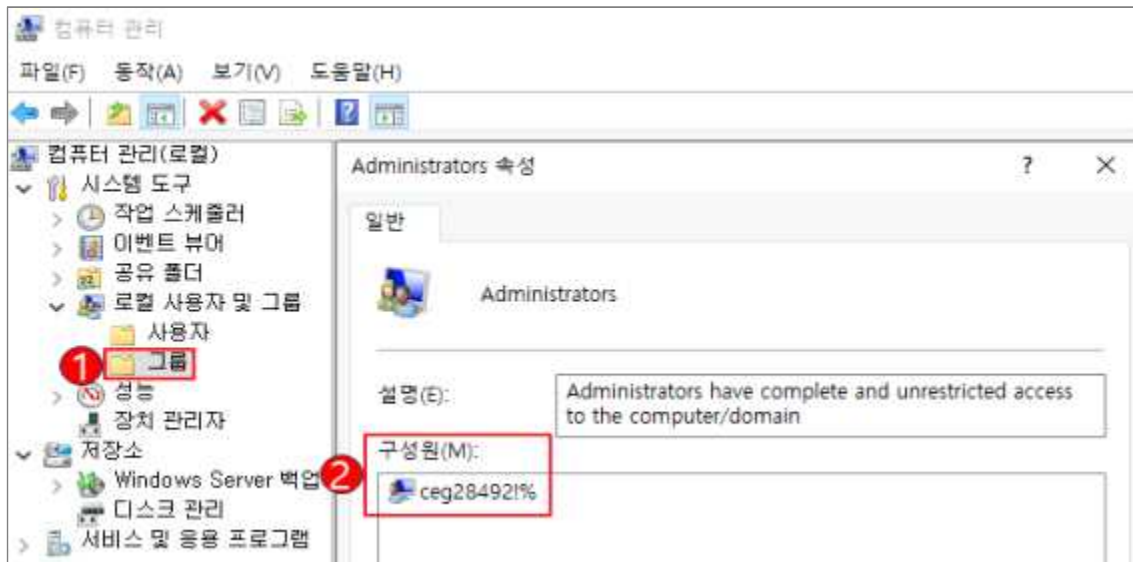
Step 2) Administrator 그룹에서 불필요한 계정 제거 후 그룹 변경

02. Windows 서버

- Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 컴퓨터 관리 > 로컬 사용자 및 그룹 > 그룹 > Administrators > 속성

Step 2) Administrators 그룹에서 불필요한 계정 제거 후 그룹 변경



[관리자 계정 그룹 불필요한 계정 확인]

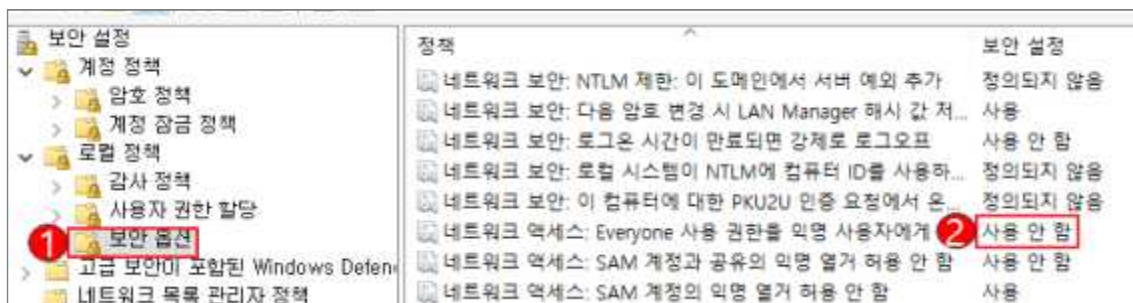
W-07 (중)	Windows 서버 > 1. 계정 관리
	Everyone 사용 권한을 익명 사용자에게 적용
개요	
점검 내용	“Everyone 사용 권한을 익명 사용자에게 적용” 정책의 설정 여부 점검
점검 목적	익명 사용자가 Everyone 그룹으로 사용 권한을 준 모든 리소스에 접근하는 것을 차단하여 비인가자에 의한 접근 가능성을 제한하기 위함
보안 위협	해당 정책이 “사용”으로 설정될 경우 권한이 없는 사용자가 익명으로 계정 이름 및 공유 리소스를 나열하고 이 정보를 사용하여 암호를 추측하거나 DoS(Denial of Service) 공격을 실행할 위험이 존재함
참고	※ DoS(Denial of Service): 관리자 권한 없이도 특정 서버에 처리할 수 없을 정도로 대량의 접속 신호를 한꺼번에 보내 해당 서버가 마비되도록 하는 해킹 기법
점검 대상 및 판단 기준	
대상	2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “Everyone 사용 권한을 익명 사용자에게 적용” 정책이 “사용 안 함”으로 되어 있는 경우
	취약 : “Everyone 사용 권한을 익명 사용자에게 적용” 정책이 “사용”으로 되어 있는 경우
조치 방법	“Everyone 사용 권한을 익명 사용자에게 적용” 정책을 “사용 안 함”으로 설정
조치 시 영향	응용프로그램이나 Backup 용도로 Everyone 공유를 사용하지 않는지 확인 필요

점검 및 조치 사례

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “Everyone 사용 권한을 익명 사용자에게 적용”을 “사용 안 함”으로 설정



[Everyone 사용 권한을 익명 사용자에게 적용 정책 설정]

02. Windows 서버

W-08 (중)	Windows 서버 > 1. 계정 관리
	계정 잠금 기간 설정
개요	
점검 내용	사용자 계정 잠금 기간 정책 설정 여부 점검
점검 목적	로그인 실패 임계값 초과 시 일정 시간 동안 계정 잠금을 실시하여 공격자의 자유로운 비밀번호 유추 공격을 차단하기 위함
보안 위협	로그인 실패 시 일정 시간 동안 계정 잠금을 하지 않은 경우, 공격자의 자동화된 비밀번호 추측 공격이 가능하며, 사용자 계정의 비밀번호 정보가 유출될 위험이 존재함
참고	※ 계정 잠금 기간 설정은 계정 잠금 임계값을 초과한 사용자 계정이 잠기는 시간을 결정함. 잠긴 계정은 관리자가 재설정하거나 해당 계정의 잠금 유지 시간이 만료되어야 사용할 수 있음 ※ 계정 잠금 기간 설정을 사용하면 해당 기간 잠긴 계정은 사용할 수 없으며, 계정 잠금이 해제될 때까지 접근할 수 없음 ※ 계정 잠금 정책: 해당 계정이 시스템으로부터 잠기는 환경과 시간을 결정하는 정책으로 '계정 잠금 기간', '계정 잠금 임계값', '다음 시간 후 계정 잠금 수를 원래대로 설정'의 세 가지 하위 정책을 가짐
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “계정 잠금 기간” 및 “계정 잠금 기간 원래대로 설정 기간”이 60분 이상으로 설정된 경우
	취약 : “계정 잠금 기간” 및 “잠금 기간 원래대로 설정 기간”이 설정되지 않거나 60분 미만으로 설정된 경우
조치 방법	“계정 잠금 기간” 및 “잠금 기간 원래대로 설정 기간” 60분 이상으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Window NT

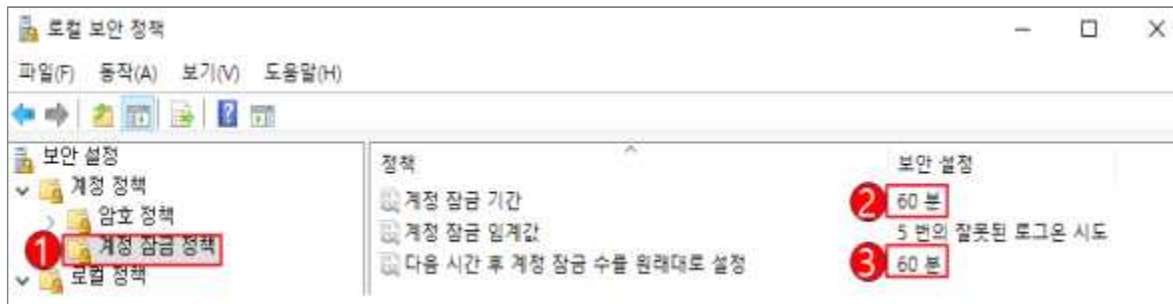
Step 1) 시작 > 프로그램 > 관리 도구 > 도메인 사용자 관리자 > 정책 > 계정 정책

Step 2) “횟수 다시 설정”을 “60분”으로 설정, “잠금 유지 기간”의 “시간제한”을 “60분”으로 설정

- Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 계정 정책 > 계정 잠금 정책

Step 2) “계정 잠금 기간”, “다음 시간 후 계정 잠금 수를 원래대로 설정”에 대해 각각 “60분” 설정



[계정 잠금 정책 설정]

02. Windows 서버

W-09 (상)	Windows 서버 > 1. 계정 관리
	비밀번호 관리 정책 설정
개요	
점검 내용	계정 비밀번호 관리 정책 설정 여부 점검
점검 목적	비밀번호 설정 시 복잡성, 최소 비밀번호 길이, 최대/최소 사용 기간을 만족하도록 함
보안 위협	사용자 비밀번호 관리 정책 설정을 만족하지 못하면 무차별 대입 공격(Brute Force Attack)이나 비밀번호 추측 공격>Password Guessing Attack)에 쉽게 크랙 될 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 계정 비밀번호 관리 정책이 모두 적용된 경우
	취약 : 계정 비밀번호 관리 정책이 모두 적용되어 있지 않은 경우
조치 방법	비밀번호 복잡성, 최소 비밀번호 길이, 최대/최소 사용 기간을 기준에 맞게 설정
조치 시 영향	일반적인 경우 영향 없음

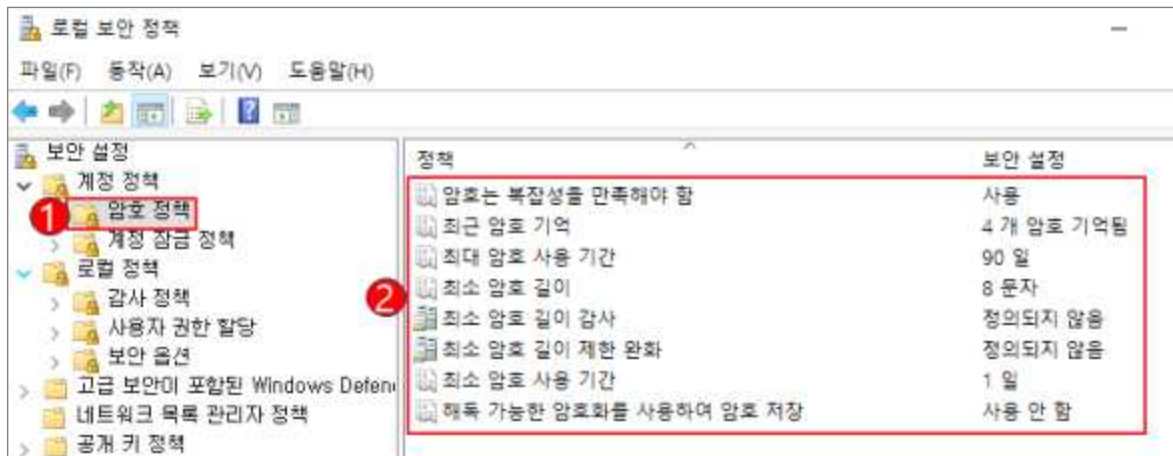
점검 및 조치 사례

● Windows NT

- Step 1) 시작 > 프로그램 > 관리 도구 > 도메인 사용자 관리자 > 정책 > 계정
- Step 2) “최소 암호 길이”에 “최소”를 “8문자”로 설정
- Step 3) “최대 암호 사용 기간”의 “사용 기간”을 “90일”로 설정
- Step 4) “최소 암호 사용 기간”에서 “사용 기간”을 “1일”로 설정
- Step 5) “암호 유일성”에서 “기억”을 “4개”로 설정

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

- Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 계정 정책 > 암호 정책
- Step 2) “암호는 복잡성을 만족해야 함”을 “사용”으로 설정
- Step 3) “최근 암호 기억”을 “4개 암호 기억됨”으로 설정
- Step 4) “최대 암호 사용 기간”의 다음 이후 암호 만료 기간을 “90일”로 설정
- Step 5) “최소 암호 길이”를 “8문자”로 설정
- Step 6) “최소 암호 사용 기간”을 “1일”로 설정



[암호 정책 설정]

※ 해당 정책 설정은 비밀번호를 변경하거나 새로운 비밀번호 생성 시 아래와 같은 일련의 규정을 만족하는지 결정함. 영문, 숫자, 특수문자 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성

가. 영문 대문자(26개)

나. 영문 소문자(26개)

다. 숫자(10개)

라. 특수문자(32개)

02. Windows 서버

W-10 (중)	Windows 서버 > 1. 계정 관리
	마지막 사용자 이름 표시 안 함
개요	
점검 내용	로그인 화면에 마지막 로그인 사용자 이름을 표시하지 않도록 설정되었는지를 점검
점검 목적	Windows 로그인 화면에 마지막 로그인한 사용자 이름이 표시되지 않도록 하여 악의적인 사용자에게 계정 정보가 노출되는 것을 차단하고자 함
보안 위협	마지막으로 로그인한 사용자의 이름이 로그인 대화상자에 표시될 경우 공격자는 이를 획득하여 비밀번호를 추측하거나 무작위 공격을 시도할 위험이 존재함
참고	※ Windows 로그인 화면에 마지막 로그인한 사용자 이름이 표시될 경우 주로 콘솔 사용자 및 터미널 서비스 이용자에게 시스템에 존재하는 사용자 계정 정보를 노출함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “마지막 사용자 이름 표시 안 함”이 “사용”으로 설정된 경우
	취약 : “마지막 사용자 이름 표시 안 함”이 “사용 안 함”으로 설정된 경우
조치 방법	※ Windows NT: 마지막으로 로그인한 사용자 이름 표시 안 함 설정 ※ Windows 2000: 로그인 스크린에 마지막 사용자 이름 표시 안 함 사용 설정 ※ Windows 2003, 2008, 2012, 2016, 2019, 2022: 대화형 로그인: 마지막 사용자 이름 표시 안 함 사용 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 프로그램 > 관리 도구 > 시스템 정책 편집기 > 파일 > 레지스트리 열기 > 로컬 컴퓨터 > 편집 > 등록 정보 > Windows NT 시스템 > 로그인 > “마지막으로 로그인한 사용자 이름 표시 안 함”을 설정한 후 저장

● Windows 2000

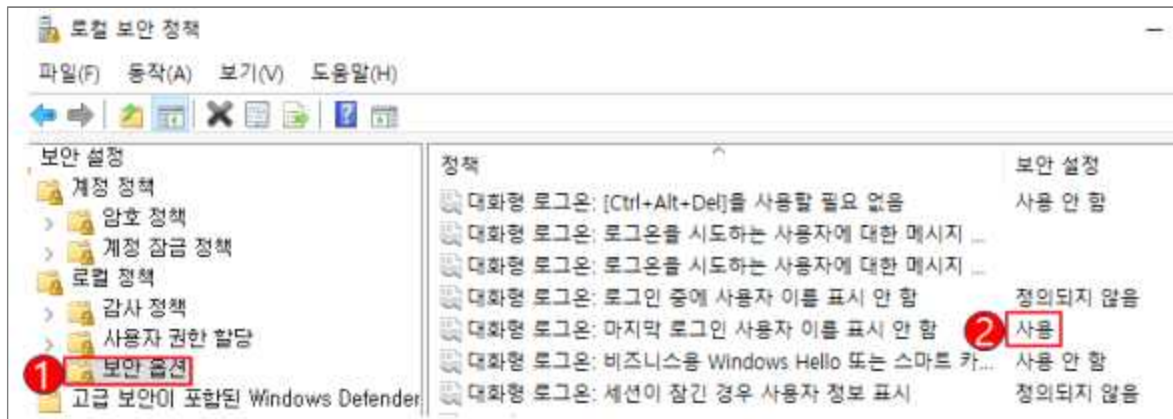
Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “로그인 스크린에 마지막 사용자 이름 표시 안 함”을 “사용”으로 설정

- Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “대화형 로그인: 마지막 사용자 이름 표시 안 함”을 “사용”으로 설정



[마지막 로그인 사용자 이름 표시 안 함]

W-11 (중)	Windows 서버 > 1. 계정 관리
	로컬 로그인 허용
개요	
점검 내용	불필요한 계정의 로컬 로그인을 허용 여부 점검
점검 목적	불필요한 계정에 로컬 로그인이 허용될 경우를 찾아 비인가자의 불법적인 시스템 로컬 접근을 차단하고자 함
보안 위협	불필요한 사용자에게 로컬 로그인이 허용될 경우 비인가자를 통한 권한 상승을 위한 악성 코드 실행 위험이 존재함
참고	※ “로컬로 로그인 허용” 권한은 시스템 콘솔에 로그인을 허용하는 권한으로 반드시 콘솔 접근이 필요한 사용자 계정에만 해당 권한을 부여해야 함 ※ IIS 서비스를 사용할 경우 이 권한에 IUSR_〈ComputerName〉 계정을 할당함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 로컬 로그인 허용 정책에 Administrators, IUSR_ 만 존재하는 경우
	취약 : 로컬 로그인 허용 정책에 Administrators, IUSR_ 외 다른 계정 및 그룹이 존재하는 경우
조치 방법	Administrators, IUSR_ 외 다른 계정 및 그룹의 로컬 로그인 제한
조치 시 영향	Administrators, IUSR_ 계정 외 로컬에서 접속이 필요한 계정 삭제 시 사용 중인 서비스에 장애를 줄 수 있음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 사용자 권한 할당

Step 2) “로컬 로그온 허용(또는, 로컬 로그온)” 정책에 “Administrators”, “IUSR_” 외 다른 계정 및 그룹 제거



[로컬 로그인 허용 정책 설정]

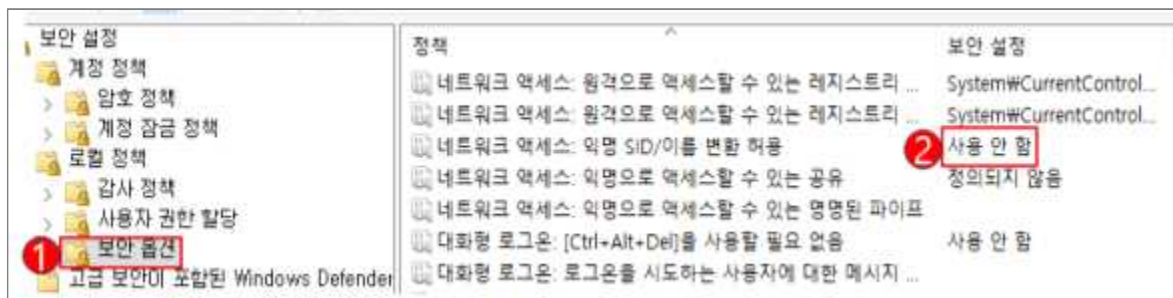
W-12 (중)	Windows 서버 > 1. 계정 관리
	익명 SID/이름 변환 허용 해제
개요	
점검 내용	익명 SID/이름 변환 정책 적용 여부 점검
점검 목적	익명 SID/이름 변환 정책을 “사용 안 함”으로 설정하여, SID(보안 식별자)를 사용하여 관리자 이름을 찾을 수 없도록 하기 위함
보안 위협	해당 정책이 “사용함”으로 설정될 경우 로컬 접근 권한이 있는 사용자가 잘 알려진 Administrator SID를 사용하여 Administrator 계정의 실제 이름을 알아낼 수 있으며 암호 추측 공격 위험이 존재함
참고	※ 해당 정책이 설정될 경우 익명 사용자가 다른 사용자의 SID(보안 식별자) 특성을 요청할 수 있음 ※ “사용 안 함”으로 정책을 설정할 경우 Windows NT 도메인 환경에서 통신 불가능하게 될 수 있음
점검 대상 및 판단 기준	
대상	Windows 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “익명 SID/이름 변환 허용” 정책이 “사용 안 함”으로 설정된 경우
	취약 : “익명 SID/이름 변환 허용” 정책이 “사용”으로 설정된 경우
조치 방법	“네트워크 액세스: 익명 SID/이름 변환 허용” 정책 “사용 안 함” 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “네트워크 액세스: 익명 SID/이름 변환 허용” 정책이 “사용 안 함”으로 설정



[익명 SID/이름 변환 허용]

※ Windows Server 2000 이하 버전 해당 사항 없음

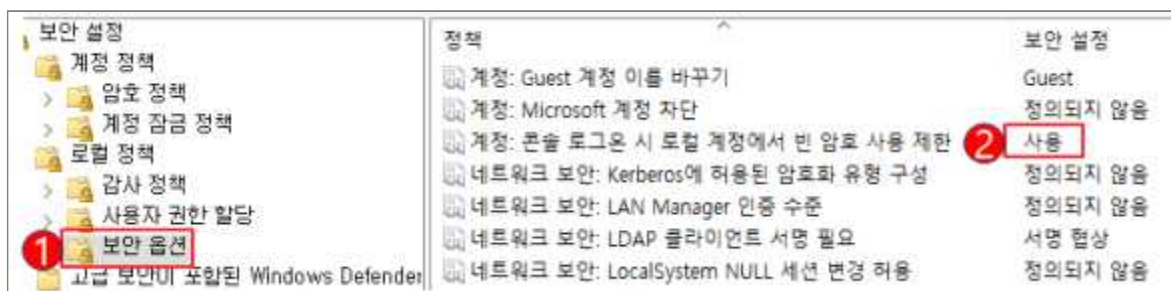
W-13 (중)	Windows 서버 > 1. 계정 관리
	콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한
개요	
점검 내용	콘솔 로그인 시 빈 비밀번호 사용 가능 여부 점검
점검 목적	빈 비밀번호를 가진 계정의 콘솔 및 네트워크 서비스 접근을 차단하기 위함
보안 위험	해당 정책이 “사용 안 함”으로 설정될 경우 빈 비밀번호를 가진 로컬 계정에 대하여 터미널 서비스(원격 데스크톱 서비스), Telnet 및 FTP와 같은 네트워크 서비스의 원격 대화형 로그인이 가능하여, 시스템 내부 정보 유출 위험이 존재함
참고	※ 윈도우 원격 제어(mstsc)는 보안상 계정에 비밀번호가 걸린 계정만 접속하도록 하고 있으나 해당 정책을 활성화하면 계정에 비밀번호가 걸려 있지 않아도 원격 제어가 가능함
점검 대상 및 판단 기준	
대상	Windows 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한” 정책이 “사용”인 경우
	취약 : “콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한” 정책이 “사용 안 함”인 경우
조치 방법	“계정: 콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한” 정책을 “사용”으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “계정: 콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한” 정책을 “사용”으로 설정



[콘솔 로그인 시 로컬 계정에서 빈 암호 사용 제한 설정]

W-14 (중)	Windows 서버 > 1. 계정 관리
	원격터미널 접속 가능한 사용자 그룹 제한
개요	
점검 내용	원격터미널 사용자 그룹 내 비인가자 포함 여부 점검
점검 목적	비인가자의 원격터미널 접속을 제한하기 위함
보안 위협	원격터미널의 그룹이나 계정을 제한하지 않으면 임의의 사용자가 원격으로 접속하여 해당 서버에 정보를 변경하거나 정보가 유출될 위험이 존재함
참고	※ 컴퓨터 관리 > 로컬 사용자 및 그룹 > Remote Desktop Users 그룹에서 추가 가능
점검 대상 및 판단 기준	
대상	Windows 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : (관리자 계정을 제외한) 원격 접속이 가능한 계정을 생성하여 타 사용자의 원격 접속을 제한하고, 원격 접속 사용자 그룹에 불필요한 계정이 등록되어 있지 않은 경우
	취약 : (관리자 계정을 제외한) 원격 접속이 가능한 별도의 계정이 존재하지 않는 경우
조치 방법	관리자 계정과 이외의 계정을 생성, 권한을 제한 사용 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2003

Step 1) 제어판 > 사용자 계정 > 관리자 계정 이외의 계정 생성한 후

Step 2) 제어판 > 시스템 > [원격] 탭 > [원격] 탭 메뉴에서 “사용자가 이 컴퓨터에 원격으로 연결할 수 있음”에 체크 > “원격 사용자 선택”에서 원격 사용자 지정 후 확인

● Windows 2008

Step 1) 제어판 > 사용자 계정 > 관리자 계정 이외의 계정 생성한 후

Step 2) 제어판 > 시스템 > 원격 설정 > [원격] 탭 > [원격 데스크톱] 메뉴 > “모든 버전의 원격 데스크톱을 실행 중인 컴퓨터에서 연결 허용(보안 수준 낮음)” 또는 “네트워크 수준 인증을 사용하여 원격 데스크톱을 실행하는 컴퓨터에서만 연결 허용(보안 수준 높음)” 중 하나에 체크 > “사용자 선택”에서 원격 사용자 지정 후 확인

- Windows 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 사용자 계정 > 계정 관리 > 관리자 계정 이외의 계정 생성

Step 2) 시작 > 제어판 > 시스템 > 원격 설정 > [원격] 탭 > [원격 데스크톱] 메뉴 > “이 컴퓨터에 대한 원격 연결 허용”에 체크 > “사용자 선택”에서 원격 사용자 지정 후 확인



[원격 데스크톱 사용자 지정 설정]

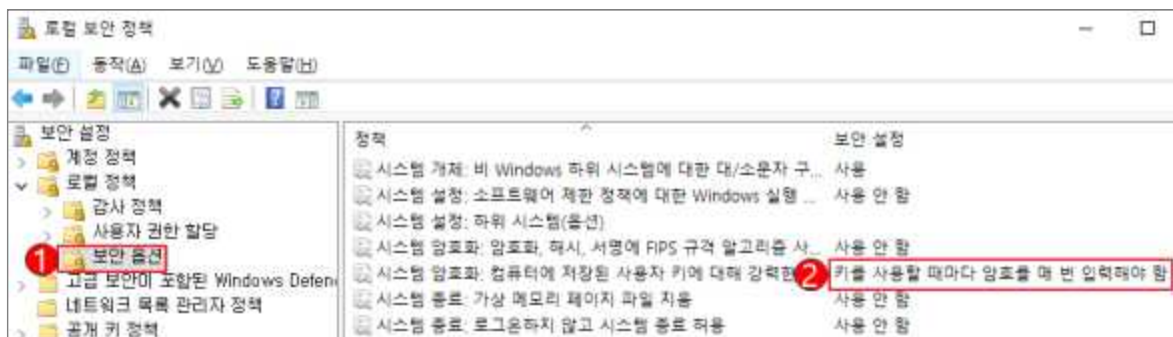
W-15 (상)	Windows 서버 > 2. 서비스 관리
	사용자 개인키 사용 시 암호 입력
개요	
점검 내용	사용자 개인 키 사용 시 비밀번호 입력 여부 점검
점검 목적	디지털 인증서 소유자와 발급 기관 모두 컴퓨터, 저장 장치 또는 개인 키를 보관 사용하는 보호 해야 함
보안 위협	사용자 개인 키 암호 입력을 사용하지 않을 경우, 공격자는 해당 키를 사용하여 네트워크 인프라에 액세스해 데이터 유출 등의 위험이 존재함
참고	※ PKI의 초석은 정보를 암호화하거나 디지털 서명하는 데 사용되는 개인 키로 도난당하게 되면 공격자가 개인 키를 사용하여 문서에 디지털 서명하고 인증된 사용자인 것처럼 가장할 수 있으므로 PKI를 통해 얻은 인증 및 부인 방지가 손상됨
점검 대상 및 판단 기준	
대상	Windows 2016, 2019, 2022
판단 기준	양호 : 사용자 개인 키를 사용할 때마다 암호 입력을 받는 경우
	취약 : 사용자 개인 키를 사용할 때마다 암호 입력을 받지 않는 경우
조치 방법	“시스템 암호화: 컴퓨터에 저장된 사용자 키에 대해 강력한 키 보호 사용” 정책을 “키를 사용할 때마다 암호를 매 번 입력해야 함”으로 적용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “시스템 암호화: 컴퓨터에 저장된 사용자 키에 대해 강력한 키 보호 사용” 정책을 “키를 사용할 때마다 암호를 매 번 입력해야 함”으로 적용



[컴퓨터에 저장된 사용자 키에 대해 강력한 키 보호 사용 설정]

W-16 (상)	Windows 서버 > 2. 서비스 관리
	공유 권한 및 사용자 그룹 설정
개요	
점검 내용	공유 디렉터리 내 Everyone 권한 존재 여부 점검
점검 목적	기본 공유인 C\$, D\$, Admin\$, IPC\$ 등을 제외한 공유 폴더에 Everyone 그룹으로 공유되는 것을 금지하여 익명 사용자의 접근을 차단하기 위함
보안 위협	Everyone이 공유계정에 포함되어 있으면 익명 사용자의 접근이 가능하여 내부 정보 유출 및 악성 코드 감염 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 일반 공유 디렉터리가 없거나 공유 디렉터리 접근 권한에 Everyone 권한이 없는 경우
	취약 : 일반 공유 디렉터리의 접근 권한에 Everyone 권한이 있는 경우
조치 방법	공유 디렉터리 접근 권한에서 Everyone 권한 제거 후 필요한 계정 추가
조치 시 영향	응용프로그램이나 Backup 용도로 Everyone 공유를 사용하는 경우 해당 작업에 영향 가능

점검 및 조치 사례

● Windows NT

Step 1) 프로그램 > 관리 도구 > 서버 관리자 > 컴퓨터 > 공유 디렉터리 > 등록 정보 > 사용 권한에서 Everyone으로 설정된 공유를 제거하고 접근이 필요한 계정에 적절한 권한 추가

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 실행 > FSMGMT.MSC > 공유

Step 2) 사용 권한에서 Everyone으로 된 공유를 제거하고 접근이 필요한 계정의 적절한 권한 추가



[공유 폴더 사용 권한 설정]

W-17 (상)	Windows 서버 > 2. 서비스 관리
	하드디스크 기본 공유 제거
개요	
점검 내용	하드디스크 기본 공유 제거 여부 점검
점검 목적	하드디스크 기본 공유를 제거하여 시스템 정보 노출을 차단하고자 함
보안 위협	Windows는 프로그램 및 서비스를 네트워크나 컴퓨터 환경에서 관리하기 위해 시스템 기본 공유 항목을 자동으로 생성함. 이를 제거하지 않으면 비인가자가 모든 시스템 자원에 접근할 수 있는 위험한 상황이 발생할 수 있으며 이러한 공유 기능의 경로를 이용하여 바이러스가 침투 위험이 존재함
참고	※ 기본 공유 : 관리 목적으로 자동 생성되는 공유 드라이브(Administrative share). 이러한 드라이브 들은 C\$, D\$, E\$ 등과 같이 이름 뒤에 \$가 붙어서 숨겨진 공유로 처리되며, Windows 2000, XP 에서는 관리자 ID와 Password를 알고 있으면 네트워크를 통해 이러한 공유 드라이브들에 자유롭게 접근할 수 있음. 그러나 이후 버전 Windows에서는 보안상의 이유로 로컬 시스템의 관리자가 네트워크를 통해 시스템을 관리하지 못하도록 기본적으로 차단됨
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 레지스트리의 AutoShareServer (WinNT: AutoShareWks)가 0이며 기본 공유가 존재하지 않는 경우
	취약 : 레지스트리의 AutoShareServer (WinNT: AutoShareWks)가 1이거나 기본 공유가 존재하는 경우
조치 방법	기본 공유 중지 후 레지스트리 값 설정(IPC\$, 일반 공유 제외)
조치 시 영향	Active Directory, Clustered system에서 적용 시 영향 있음 Active Directory : 중앙 집중화된 자원 관리를 위한 계층적 디렉터리 서비스 Clustered system : 여러 개의 시스템을 결합하여 사용함

점검 및 조치 사례

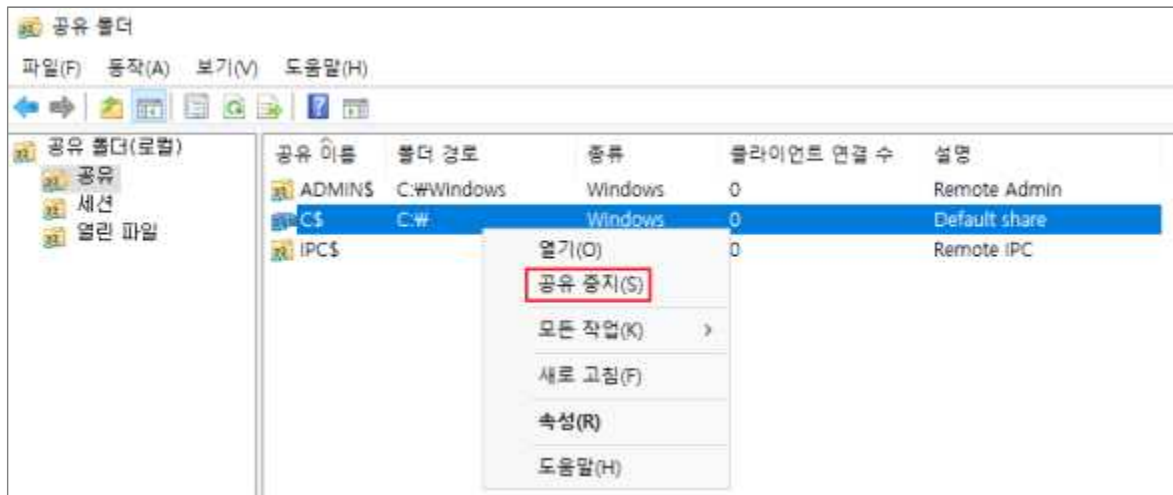
● Windows NT

Step 1) 프로그램 > 관리도구 > 서버 관리자 > 컴퓨터 > 공유 디렉터리 > 공유 > 공유 중지

02. Windows 서버

- Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 실행 > FSMGMT.MSC > 공유 > 기본 공유(Default share) 선택 > 마우스 우클릭 > 공유 중지



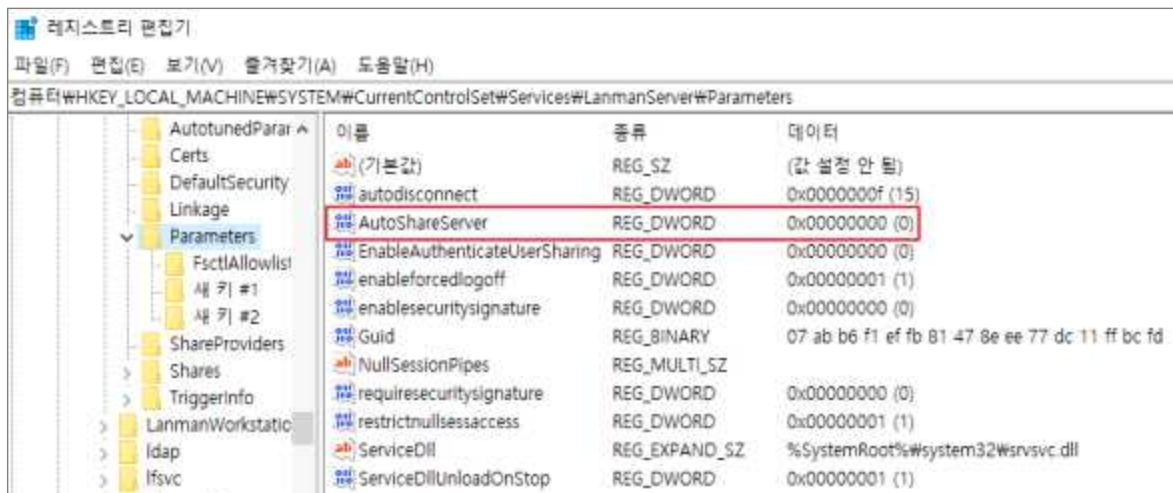
[기본 공유 폴더 중지 설정]

Step 2) 시작 > 제어판 > 관리 도구 > 레지스트리 편집기

아래 레지스트리 값을 0으로 수정(키 값이 없을 경우 새로 생성)

“HKLM\SYSTEM\CurrentControlSet\Services\Lanmanserver\parameters\”

Step 3) AutoShareServer(Windows NT: AutoShareWks)을 “0”으로 수정



[AutoShareServer 값 설정]

※ 방화벽과 라우터에서 135~139(TCP/UDP) Port를 차단하여 외부로부터의 위험을 제거함으로써 보안성을 높일 수 있음

W-18 (상)	Windows 서버 > 2. 서비스 관리
	불필요한 서비스 제거
개요	
점검 내용	불필요한 서비스 가동 여부 점검
점검 목적	사용자 환경에 필요하지 않은 서비스 및 실행 파일을 제거하거나 비활성화 처리하여 이를 통한 악의적인 공격을 차단하기 위함
보안 위협	시스템에 기본적으로 설치되는 불필요한 취약 서비스들이 제거되지 않은 경우, 해당 서비스의 취약점으로 인한 공격이 가능하며, 네트워크 서비스의 경우 열린 Port를 통한 외부 침입 위험이 존재함
참고	※ OS 버전에 따라 '일반적으로 불필요한 서비스' 목록에 나열된 서비스가 제공되지 않을 수 있음
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 일반적으로 불필요한 서비스(아래 목록 참조)가 중지된 경우
	취약 : 일반적으로 불필요한 서비스(아래 목록 참조)가 구동 중인 경우
조치 방법	서비스 중지 후 "사용 안 함" 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT

- Step 1) 시작 > 설정 > 제어판 > 서비스를 선택하여 불필요한 서비스를 중지하고, 시작 옵션에서 "시작 유형"을 "사용 안 함"으로 수정
- Step 2) 해당 서비스를 선택하고 오른쪽 메뉴에서 "시작 옵션"을 클릭하면 시스템이 시작할 때에 해당 서비스의 시작 유형을 선택할 수 있음. 만약, 시스템 시작 시 자동으로 시작되게 하려면 [자동], 수동으로 서비스를 시작하려면 [수동], 서비스 자체를 사용하지 않으려면 [사용 안 함]을 선택한 후 [확인]을 클릭함

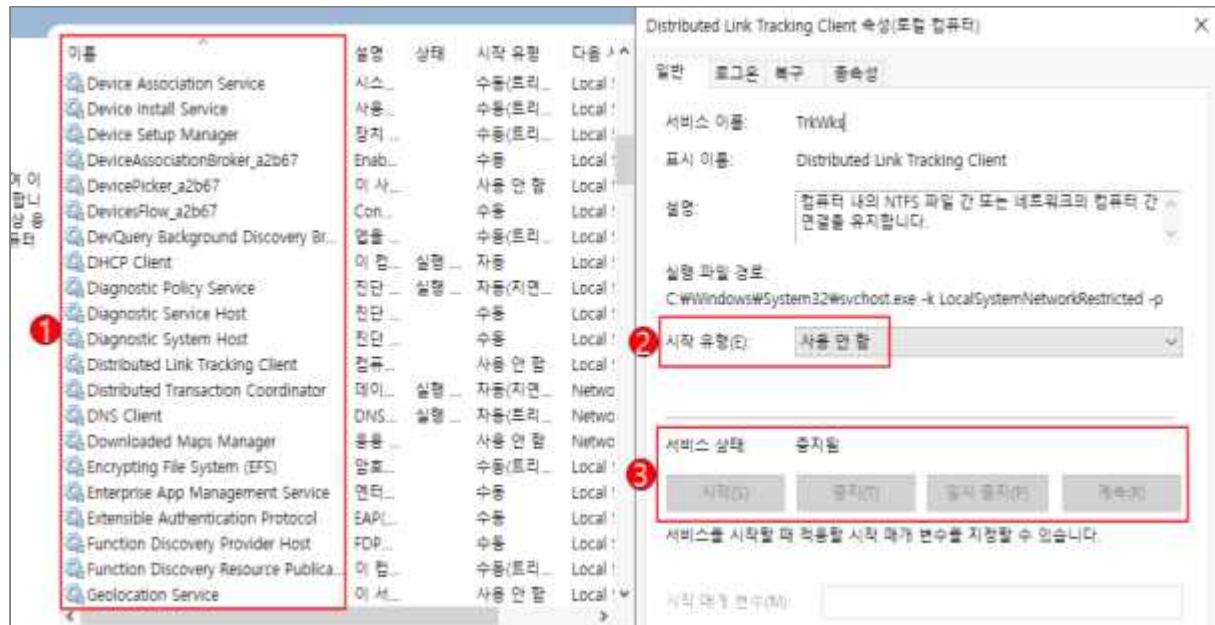
02. Windows 서버

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 서비스 > "해당 서비스" 선택 > 속성

Step 2) 시작 유형 -> 사용 안 함

Step 3) 서비스 상태 -> 중지 설정



[불필요한 서비스 중지 설정]

※ 특별한 목적을 위해 사용하는 서비스가 아니라면 시스템의 업무에 부합되는 서비스가 아닌 기타 기본 서비스를 사용하지 않는 것을 권고하며, 시스템 관리자는 대상 시스템의 용도를 정확히 파악해 불필요한 서비스를 제거해야 함

서비스 시작 유형	설명
사용 안 함	설치되어 있으나 실행되지 않음
수동	다른 서비스나 응용 프로그램에서 해당 기능을 필요로 할 때만 시작됨
자동	부팅 시에 해당 장치 드라이버가 로드된 후에 운영체제에 의해 시작됨

※ 각 서비스마다 옵션을 설정할 수 있으며 해당 서비스의 시작 유형을 선택할 수 있으며 시작 시 로그인 계정을 별도로 설정할 수 있음. 만약, 시스템 시작 시 자동으로 시작되게 하려면 [자동], 수동으로 서비스를 시작하려면 [수동], 서비스 자체를 사용하지 않으려면 [사용 안 함]을 선택

※ 일반적으로 불필요한 서비스

서비스명	기능 및 설명
Alerter	네트워크상에서 사용자와 컴퓨터에 관리용 경고 메시지를 전송하는 기능
Automatic Updates	중요한 윈도우 업데이트를 다운로드하고 설치할 수 있도록 하는 응용프로그램. 수동 패치를 적용하거나, MS 패치 관리 서버로 패치를 일괄적으로 관리하는 경우 불필요한 서비스
Clipbook	서버 내 Clipbook을 다른 클라이언트와 공유
Computer Browser	네트워크에 있는 모든 컴퓨터의 목록을 업데이트하고 관리하는 기능
Cryptographic Services	윈도우 파일의 서명을 확인하는 카탈로그 데이터베이스 서비스를 총괄
DHCP Client	IP주소와 DNS 이름을 DHCP 서버에 등록하거나 DHCP 서버로부터 동적으로 IP주소를 가져오는 기능을 수행. 단독으로 시스템을 수행하며 고정 IP를 사용하는 경우 불필요한 서비스
Distributed Link Tracking Client, Server	네트워크 도메인의 여러 컴퓨터나 일반 컴퓨터에서 NTFS 파일간의 연결을 관리하는 도구. Active Directory가 구성되어 있지 않은 서버에서는 불필요한 서비스
DNS Client	컴퓨터에 대한 도메인 이름 시스템(DNS) 이름을 확인하고 캐시에 보관하는 기능. DNS 서버가 아닌 시스템에서는 유명무실하나, IPSEC을 사용하는 경우에는 필요할 수 있음
Error reporting Service	프로그램 오류가 발생 시 응용프로그램의 오류를 MS에 보고한다는 내용을 표시하는 기능
Human Interface Device Access	키보드 또는 기타 멀티미디어 장치에 사전 정의된 버튼들을 사용하는 HID 장치들을 위한 서비스
IMAPI CD-Burning COM Service	서버에 CD-RW 또는 DVD-RW가 장착되어 보조백업장치 역할을 하기 위해서 자체 레코딩 백업을 할 수 있음
Infrared Monitor	사용자 적외선 연결을 통해 파일 및 이미지를 공유할 수 있도록 함
Messenger	클라이언트와 서버 사이에 netsend 및 경고서비스 메시지를 전송하는 기능
NetMeeting Remote Desktop Sharing	윈도우9X 운영체제부터 인증된 사용자가 넷미팅을 사용해서 원격으로 컴퓨터에 접근할 수 있도록 하는 기능
Portable Media Serial Number	컴퓨터에 연결된 이동성 음악 연주기(미디어기기)의 등록번호를 복원하는 기능
Print Spooler	인쇄 과정에 있는 스푼링을 관리하는 서비스. 프린터가 있는 경우 필수 서비스이지만, 프린터가 연결되지 않은 시스템에서는 불필요함
Remote Registry	원격 사용자가 이 컴퓨터에서 레지스트리 설정을 수정할 수 있도록 설정하는 응용프로그램
Simple TCP/IP Services	Echo, Discard, Character Generator, Daytime, Quote of the Day 지원

02. Windows 서버

서비스명	기능 및 설명
Universal Plug and Play Device Host	네트워크 장치에 대해 피어-투-피어 UPnP(범용 플러그 앤 플레이) 기능을 지원
Wireless Zero Configuration	802.11 어댑터에 대해 자동 구성을 공급하는 기본적인 도구

※ 운영 중인 시스템에서 필수 서비스를 정의하는 것은 매우 복잡한 과정으로 서비스 사용 여부는 시스템의 영향을 고려하여 신중하게 평가되어야 하므로 Microsoft에서 권고하는 가이드에 따라 전략적으로 적용해야 함

※ <https://technet.microsoft.com/ko-kr/library/dd547941.aspx> (서비스 및 서비스 계정 보안 계획 가이드) 참고

※ 윈도우 시스템 설치 시 기본적으로 설치되는 서비스에 대한 상세 설명은 아래 주소 참조
<https://technet.microsoft.com/ko-kr/library/dd547949.aspx>

W-19 (상)	Windows 서버 > 2. 서비스 관리
	불필요한 IIS 서비스 구동 점검
개요	
점검 내용	불필요한 IIS 서비스 구동 여부 점검
점검 목적	불필요한 IIS 서비스가 구동 상태인지를 점검하여 제거하고, 해당 서비스가 취약점이 제거되지 않은 상태로 외부 위협에 노출되지 않도록 하기 위함
보안 위협	IIS 서비스의 WEB, FTP 등 기능이 보편적으로 사용되나, 프로파일링, 서비스 거부, 불법적인 접근, 임의의 코드 실행, 정보 공개, 바이러스, 웜, 트로이목마 등의 공격 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : IIS 서비스를 사용하지 않는 경우 또는 필요에 의해 IIS 서비스를 사용하는 경우
	취약 : IIS 서비스를 불필요하게 사용하는 경우
조치 방법	IIS 서비스가 불필요한 경우 IIS 서비스 중지
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 서비스 > World Wide Web Publishing 서비스(IISADMIN) > 속성 > "시작 유형"을 "사용 안 함" 설정 후 중지

※ IIS 미설치 시 SERVICES.MSC 에 출력되지 않음



[IIS 서비스 사용 안 함 설정]

02. Windows 서버

W-20 (상)	Windows 서버 > 2. 서비스 관리
	NetBIOS 바인딩 서비스 구동 점검
개요	
점검 내용	NetBIOS 바인딩 서비스 구동 여부 점검
점검 목적	NetBIOS와 TCP/IP 바인딩을 제거하여 TCP/IP를 거치게 되는 파일 공유 서비스를 제공하지 못하도록 하고, 인터넷에서의 공유자원에 대한 접근시도를 방지하고자 함
보안 위협	인터넷에 직접 연결된 윈도우 시스템에서 NetBIOS TCP/IP 바인딩이 활성화되어 있으면 공격자가 네트워크 공유자원을 사용할 위험이 존재함
참고	※ NetBIOS(Network Basic Input/Output System)는 별개의 컴퓨터상에 있는 응용프로그램들이 근거리통신망 내에서 서로 통신할 수 있게 해주는 API. 이름 서비스, 세션 서비스, 데이터그램 서비스를 제공하며, 주로 네트워크 장치 간의 통신을 지원
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : TCP/IP와 NetBIOS 간의 바인딩이 제거되어 있는 경우
	취약 : TCP/IP와 NetBIOS 간의 바인딩이 제거되어 있지 않은 경우
조치 방법	네트워크 제어판을 이용하여 TCP/IP와 NetBIOS 간의 바인딩(binding) 제거
조치 시 영향	TCP/IP를 거치게 되는 파일 공유 서비스가 제공되지 않음 인터넷에서의 공유자원에 대한 접근시도가 불가능함 (라우터를 거치지 않은 내부 네트워크에서는 가능함)

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 네트워크 및 공유 센터 > 어댑터 설정 변경 > 로컬 영역 연결 > 속성 > TCP/IP > [일반] 탭에서 [고급] 클릭

Step 2) [WINS] 탭에서 TCP/IP에서 “NetBIOS 사용 안 함” 또는, “NetBIOS over TCP/IP 사용 안 함” 선택



[NetBIOS 사용 안 함 설정]

02. Windows 서버

W-21 (상)	Windows 서버 > 2. 서비스 관리
	암호화되지 않는 FTP 서비스 비활성화
개요	
점검 내용	시스템 내 FTP 서비스 구동 여부 점검
점검 목적	인증정보가 기본적으로 평문 전송되는 취약한 프로토콜인 FTP의 사용을 제한하기 위함
보안 위협	OS에서 제공하는 기본적인 FTP 서비스를 사용할 경우 계정과 패스워드가 암호화되지 않은 채로 전송되어 Sniffer에 의한 계정정보의 노출 위험이 존재함
참고	※ Sniffer : 네트워크 트래픽을 감시하고 분석하는 프로그램 ※ 관련 점검항목: W-22(상), W-23(상), W-24(상)
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : FTP 서비스를 사용하지 않는 경우 또는 Secure FTP 서비스를 사용하는 경우
	취약 : 암호화되지 않는 FTP 서비스를 사용하는 경우
조치 방법	FTP 서비스가 필요하지 않다면 서비스 중지 또는 Secure FTP 응용 프로그램 사용
조치 시 영향	일반적인 경우 영향 없음

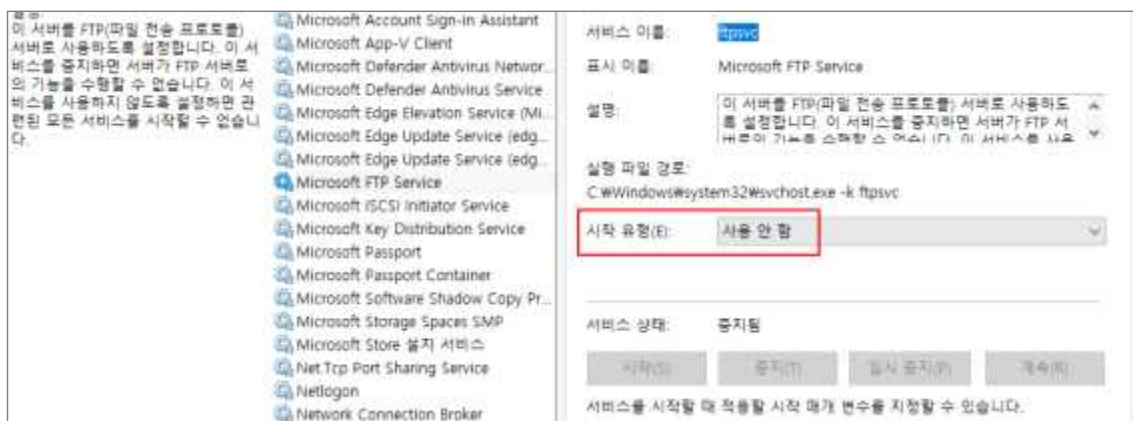
점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 실행 > SERVICES.MSC > FTP Publishing Service(Windows 2012 이상 : Microsoft FTP Service)

> 속성 >

Step 2) 시작 유형을 “사용 안 함”으로 설정한 후, FTP 서비스 중지



[FTP 서비스 사용 안 함 설정]

W-22 (상)	Windows 서버 > 2. 서비스 관리
	FTP 디렉토리 접근권한 설정
개요	
점검 내용	FTP 홈 디렉터리의 접근 권한 적절성 점검
점검 목적	FTP 서비스 디렉터리의 접근 권한을 적절하게 설정하여 의도치 않은 정보 유출을 방지하기 위함
보안 위협	FTP 홈 디렉터리에 과도한 권한(예. Everyone Full Control)이 부여된 경우 임의의 사용자가 쓰기, 수정이 가능하여 정보 유출, 파일 위변조 등의 위험이 존재함
참고	※ 기반시설 시스템은 FTP 서비스를 사용하지 않는 것이 원칙이나, 조직 내에서 해당 서비스를 부득이 사용해야 하는 경우 관련 보호 대책을 수립 및 적용하여 활용해야 함 ※ 관련 점검항목: W-21(상), W-23(상), W-24(상)
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : FTP 홈 디렉터리에 Everyone 권한이 없는 경우
	취약 : FTP 홈 디렉터리에 Everyone 권한이 있는 경우
조치 방법	FTP 홈 디렉터리에서 Everyone 권한 삭제, 각 사용자에게 적절한 권한 부여
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT(IIS 4.0), 2000(IIS 5.0), 2003(IIS 6.0)

Step 1) 인터넷 정보 서비스(IIS) 관리 > FTP 사이트 > 해당 FTP 사이트 > 속성 > [홈 디렉터리] 탭에서 FTP 홈 디렉터리 확인

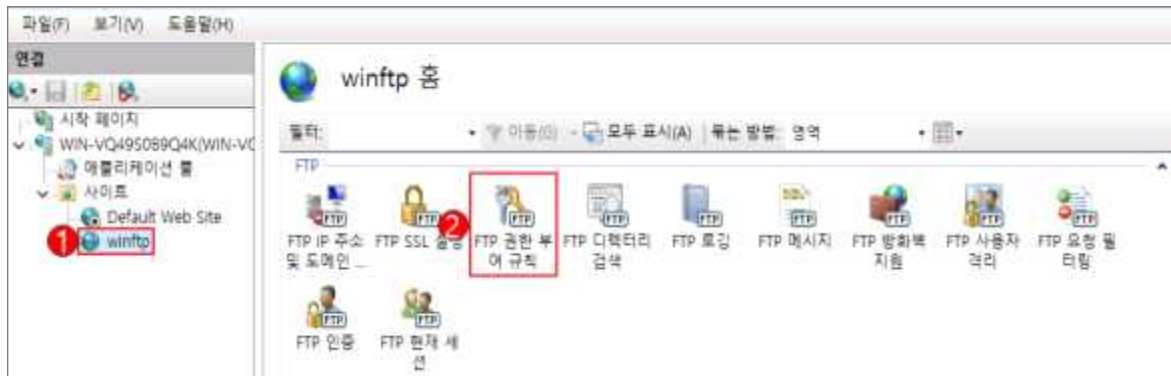
Step 2) 탐색기 > 홈 디렉터리 > 속성 > [보안] 탭에서 Everyone 권한 제거

02. Windows 서버

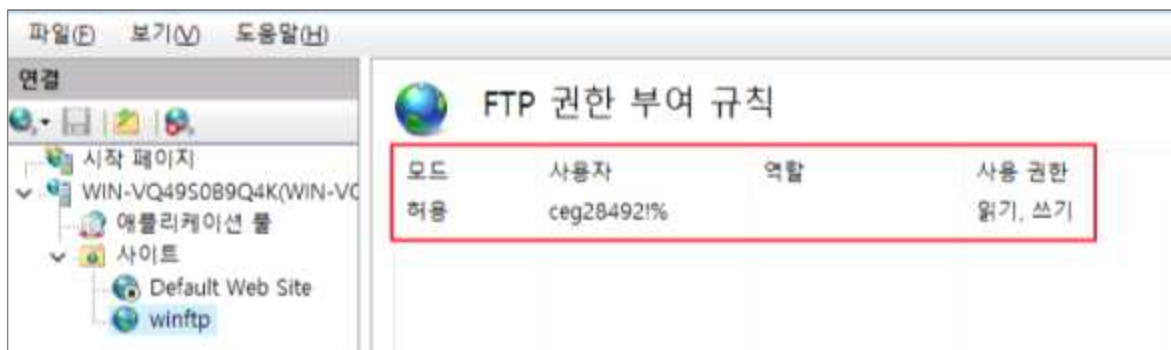
- Windows 2008(IIS 7.0), 2012(IIS 8.0), 2016, 2019, 2022(IIS 10.0)

Step 1) 제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리 > 사이트 > 해당 FTP 사이트 > FTP 권한 부여 규칙 선택

Step 2) 허용 권한 부여 규칙에서 “지정한 사용자” 지정



[FTP 권한 부여 규칙]



[지정한 사용자 설정]

W-23 (상)	Windows 서버 > 2. 서비스 관리
	공유 서비스에 대한 익명 접근 제한 설정
개요	
점검 내용	공유 서비스의 익명(Anonymous) 접속 허용 여부 점검
점검 목적	공유 익명 접속을 제한하여, 중요 정보의 불법 유출을 차단하기 함
보안 위협	공유 익명 접속이 허용되면 핵심 기밀 자료나 내부 정보의 불법 유출 위험이 존재함
참고	※ 만약 익명 접속이 허용된 공유 서버에 익명 사용자에게 쓰기 권한이 부여된 경우, 정상적으로 업로드한 파일들의 변조가 가능하므로 공개한 디렉터리 내 중요 데이터가 보관되어 있는지를 추가로 확인해야 함 ※ 공유 서비스: FTP, SMB, NFS, TFTP 등 ※ 관련 점검항목: W-21(상), W-22(상), W-24(상)
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 공유 서비스를 사용하지 않거나, 익명 인증 사용 안 함으로 설정된 경우
	취약 : 공유 서비스를 사용하거나, 익명 인증 사용함으로 설정된 경우
조치 방법	공유 서비스를 사용하지 않는 경우 서비스 중지, 사용할 경우 익명 인증 사용 안 함 설정 적용
조치 시 영향	응용프로그램에서 익명 연결을 사용할 경우를 제외하고, 일반적인 경우 영향 없음

점검 및 조치 사례

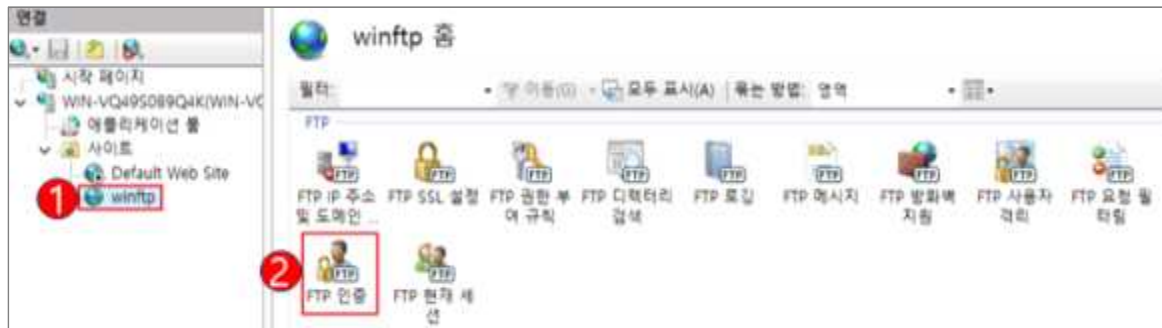
● Windows NT(IIS 4.0), 2000(IIS 5.0), 2003(IIS 6.0)

Step 1) 인터넷 정보 서비스(IIS) 관리 > FTP 사이트 > 속성 > [보안 계정] 탭에서 “익명 연결 허용” 체크박스 해제 (만약 개별 FTP 사이트에 적용할 경우 해당 사이트에만 설정이 적용되고, 기본 설정은 적용받지 않음)

02. Windows 서버

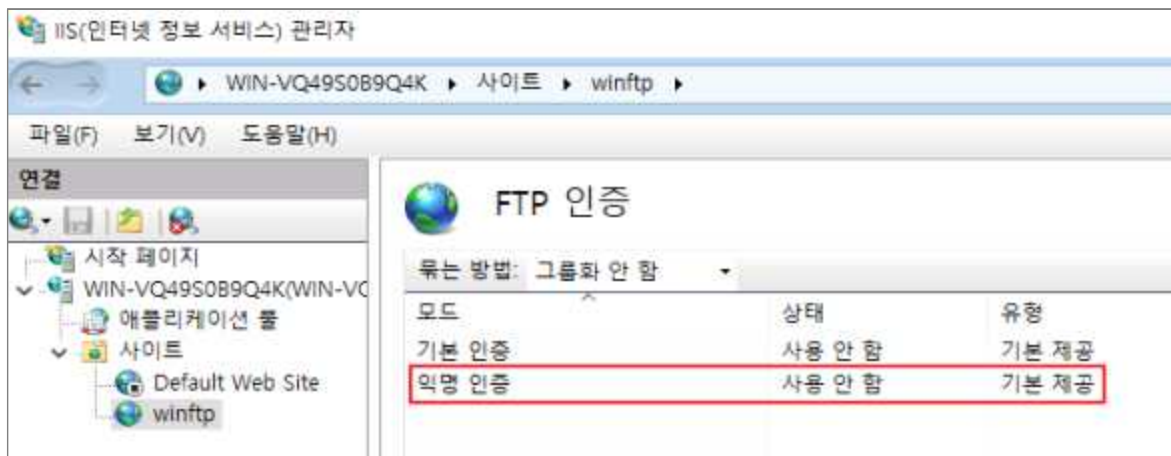
- Windows 2008(IIS 7.0), 2012(IIS 8.0), 2016, 2019, 2022(IIS 10.0)

Step 1) 제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리 > 해당 FTP 사이트 > FTP 인증 선택



[FTP 인증 설정]

Step 2) FTP 인증 화면에서 익명 인증 사용 안 함 설정



[익명 인증 사용 안 함 설정]

W-24 (상)	Windows 서버 > 2. 서비스 관리
	FTP 접근 제어 설정
개요	
점검 내용	FTP 접속 가능한 IP주소 지정 여부 점검
점검 목적	FTP 접근 시 특정 IP주소에 대해 콘텐츠 접근을 허용하여 서비스 보안성을 강화하기 위함
보안 위협	FTP 프로토콜은 로그인 시 지정된 자격 증명이나 데이터 자체가 암호화되지 않고 모든 자격 증명을 일반 텍스트로 네트워크를 통해 전송되는 특성상 서버 클라이언트 간 트래픽 스니핑을 통해 인증 정보가 쉽게 노출될 위험이 존재함
참고	※ 기반시설 시스템은 FTP 서비스를 사용하지 않는 것이 원칙이나, 조직 내에서 해당 서비스를 부득이 사용해야 하는 경우 관련 보호 대책을 수립 및 적용하여 활용해야 함 ※ 관련 점검항목: W-21(상), W-22(상), W-23(상)
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 특정 IP주소에서만 FTP 서버에 접속하도록 접근 제어 설정을 적용한 경우
	취약 : 특정 IP주소에서만 FTP 서버에 접속하도록 접근 제어 설정을 적용하지 않는 경우 ※ 조치 시 마스터 속성과 모든 사이트에 적용함
조치 방법	특정 IP주소에서만 FTP 서버에 접속하도록 접근 제어 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT(IIS 4.0), 2000(IIS 5.0), 2003(IIS 6.0)

Step 1) 인터넷 정보 서비스(IIS) 관리 > FTP 사이트 > 속성 > [디렉터리 보안] 탭에서 “액세스 거부” 선택 후 접근 가능 IP주소 추가 (만약 개별 FTP 사이트에 적용할 경우 해당 사이트에만 설정이 적용되고, 기본 설정은 적용받지 않음)

※ 액세스 허가: 모든 액세스를 허용 후 액세스를 거부할 컴퓨터, 그룹, 도메인 추가

액세스 거부: 모든 액세스를 거부 후 액세스를 허용할 컴퓨터, 그룹, 도메인 추가

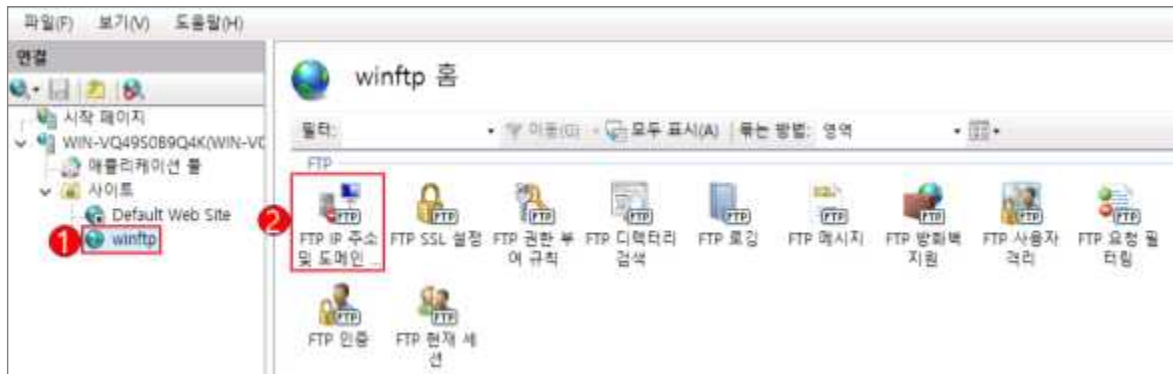
02. Windows 서버

- Windows 2008(IIS 7.0), 2012(IIS 8.0), 2016, 2019, 2022(IIS 10.0)

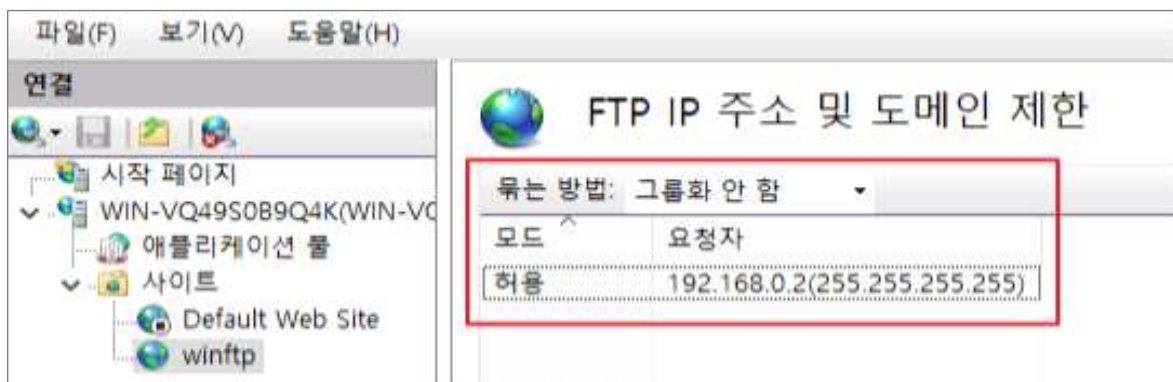
Step 1) 제어판 > 관리 도구 > 인터넷 정보 서비스(IIS) 관리 > 해당 FTP 사이트 > FTP IPv4 주소 및 도메인 제한

Step 2) [작업]의 허용 항목 추가에서 FTP 접속을 허용할 IP 입력

Step 3) [작업]의 기능 설정 편집에서 지정되지 않은 클라이언트에 대한 액세스를 거부 선택



[FTP IP주소 및 도메인 제한 설정]



[허용 IP주소 설정]

W-25 (상)	Windows 서버 > 2. 서비스 관리
	DNS Zone Transfer 설정
개요	
점검 내용	DNS Zone Transfer 차단 설정 여부 점검
점검 목적	DNS Zone Transfer 차단 설정을 적용하여 도메인 정보의 불법 외부 유출을 방지하기 위함
보안 위협	DNS Zone Transfer 차단 설정이 적용되지 않는 경우 DNS 서버에 저장된 도메인 정보를 승인된 DNS 서버가 아닌 외부로 유출 위험이 존재함
참고	※ Zone Transfer : 영역(zone) 전송이라고 하며 master와 slave 간에 또는 primary와 secondary DNS 간에 zone 파일을 동기화하기 위한 용도로 사용되는 기술
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 아래 기준에 해당하는 경우 1. DNS 서비스가 비활성화인 경우 2. 영역 전송 허용을 하지 않는 경우 3. 특정 서버로만 설정이 되어있는 경우
	취약 : 위 3개 기준 중 하나라도 해당하지 않는 경우
조치 방법	불필요 시 서비스 중지/사용 안 함 설정, 사용하는 경우 영역 전송을 특정 서버로 제한하거나 “영역 전송 허용”에 체크 해제
조치 시 영향	영역 전송 시 서버를 지정할 경우 영향 없음

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 프로그램 > 관리 도구 > DNS 관리자 > 각 조회 영역 > 해당 영역 > 등록 정보 > 알림

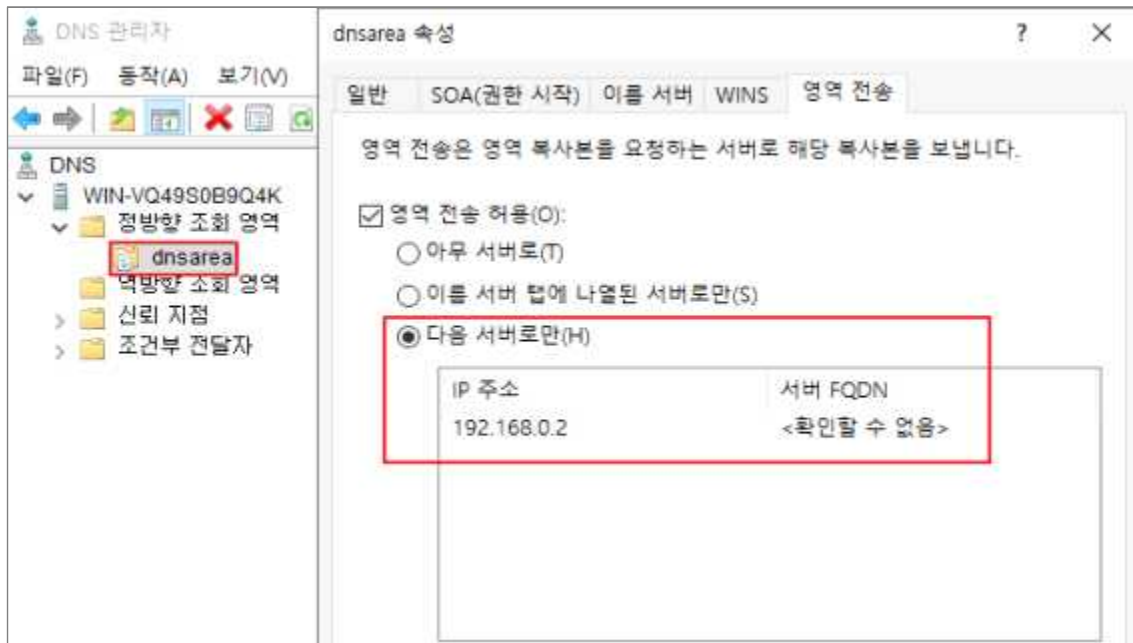
Step 2) “알림 목록에 있는 보조 영역에서만 액세스 허용” 선택 후 서버 IP 추가

02. Windows 서버

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > DNS > 각 조회 영역 > 해당 영역 > 속성 > 영역 전송

Step 2) “다음 서버로만” 선택 후 전송할 서버 IP 추가



[영역 전송 IP주소 지정]

Step 3) 불필요 시 해당 서비스 중지

시작 > 실행 > SERVICES.MSC > DNS 서버 > 속성 [일반] 탭에서 “시작 유형”을 “사용 안 함”으로 설정한 후, DNS 서비스 중지



[DNS Server 사용 안 함 설정]

W-26 (상)	Windows 서버 > 2. 서비스 관리
	RDS(Remote Data Services)제거
개요	
점검 내용	RDS(Remote Data Services) 비활성화 여부 점검
점검 목적	취약한 RDS 서비스를 제거하여 불법적인 원격 공격을 차단하기 위함
보안 위협	취약한 플랫폼의 RDS가 사용되는 경우 서비스 거부 공격이나 원격에서 관리자 권한으로 임의의 명령을 실행할 수 있는 위험이 존재함
참고	※ MDAC 2.7 미만의 버전에서 웹 서버와 웹 클라이언트 모두 취약점으로 인해 위험해질 수 있으므로 RDS가 불필요할 경우 제거하는 것이 안전함 ※ RDS(Remote Data Services) : MDAC(Microsoft Data Access Components)의 한 컴포넌트로 클라이언트에 있는 데이터를 다룰 수 있도록 하는 서비스
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003
판단 기준	양호 : 다음 중 한 가지라도 해당하는 경우 1. IIS를 사용하지 않는 경우 2. Windows 2008 이상 버전을 사용하는 경우 3. Windows 2000 서비스팩 4, Windows 2003 서비스팩 2 이상 설치된 경우 4. 기본 웹 사이트에 MSADC 가상 디렉터리가 존재하지 않는 경우 5. 해당 레지스트리 값이 존재하지 않는 경우
	취약 : 양호 기준에 한 가지도 해당하지 않는 경우
조치 방법	사용하지 않는 경우 IIS 서비스 중지/사용 안 함, 사용할 경우 레지스트리 키 값 제거 또는 관련 패치 적용
조치 시 영향	WAS와 연동될 경우 일부 RDS를 사용할 수가 있으며 사용할 경우 레지스트리 키 값 제거가 요구됨

점검 및 조치 사례

● Windows NT, 2000, 2003

Step 1) 시작 > 실행 > INETMGR > 웹 사이트 선택 후 디렉터리에서 msadc 제거

Step 2) 다음의 레지스트리 키/디렉터리 제거

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\W3SVC\Parameters\ADCLaunch

1. RDSServer.DataFactory
2. AdvancedDataFactory
3. VbBusObj.VbBusObjCls

02. Windows 서버

W-27 (상)	Windows 서버 > 2. 서비스 관리
	최신 Windows OS Build 버전 적용
개요	
점검 내용	최신 Build 적용 여부 점검
점검 목적	시스템을 최신 버전으로 유지하여 새로운 위협 및 진행 중인 위협으로부터 중요 정보와 시스템을 보호하기 위함
보안 위협	보안 업데이트를 적용하지 않으면 시스템 및 응용 프로그램의 취약성으로 인해 권한 상승, 원격 코드 실행, 보안 기능 우회 등의 위협이 존재함
참고	※ Build : Windows 패치 버전
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 최신 Build가 설치되어 있으며 적용 절차 및 방법이 수립된 경우
	취약 : 최신 Build가 설치되지 않거나, 적용 절차 및 방법이 수립되지 않은 경우
조치 방법	설치에 따른 영향도 확인 후 최신 Build 설치(설치 후 시스템 재시작 필요)
조치 시 영향	설치 후 시스템 재시작이 필요하며 설치에 따른 시스템 영향 정도를 확인해야 함

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 실행 > Winver

Step 2) Build 버전 확인 후 최신 Build 다운로드 후 설치 또는 자동업데이트 활용

※ 인터넷 웜(Worm)이 Windows의 취약점을 이용하여 공격하기 때문에 최신 패치 설치 시에는 네트워크와 분리된 상태에서 설치할 것을 권장



[Windows Build 버전 확인]

W-28 (중)	Windows 서버 > 2. 서비스 관리
	터미널 서비스 암호화 수준 설정
개요	
점검 내용	원격 데스크톱 서비스 암호화 수준 적절성 점검
점검 목적	원격 데스크톱 서비스 암호화 설정으로 데이터를 암호화하여 클라이언트와 서버 간의 통신에서 전송되는 데이터를 보호하기 위함
보안 위협	서버 접속 시에 낮은 암호화 수준을 적용할 경우 악의적인 사용자에게 의해 서버와 클라이언트 간 주고받는 정보가 노출될 위험이 존재함
참고	※ 기반시설 시스템은 원격 데스크톱 서비스의 사용을 원칙적으로 금지하나, 부득이 해당 서비스를 사용해야 하는 경우 클라이언트 서버 간의 데이터 전송 시 암호화하여 보호해야 함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 원격 데스크톱 서비스를 사용하지 않거나 사용 시 암호화 수준을 “클라이언트와 호환 가능(중간)” 이상으로 설정한 경우
	취약 : 원격 데스크톱 서비스를 사용하고 암호화 수준이 “낮음”으로 설정한 경우
조치 방법	원격 데스크톱 서비스의 가동을 ‘중지’ 및 ‘사용 안 함’ 설정을 하거나, 부득이하게 사용할 경우 암호화 수준 설정 적용
조치 시 영향	암호화 수준 변경 시 일반적으로 영향 없음

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 실행 > regedit

Step 2) HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp\
MinEncryptionLevel 값을 2(중간) 이상으로 설정

● Windows 2000

Step 1) 시작 > 실행 > TSCC.MSC > “해당 서비스” 선택 > 속성

Step 2) 암호화 수준 → 중간(Windows 2000) 이상으로 설정

02. Windows 서버

● Windows 2003

Step 1) Windows 2003: 시작 > 실행 > TSCC.MSC > “해당 서비스” 선택 > 속성

Step 2) [일반] 탭에서 암호화 수준 설정 → 클라이언트 호환 가능

● Windows 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 실행 > GPEDIT.MSC(로컬 그룹 정책 편집기)

Step 2) 컴퓨터 구성 > 관리 템플릿 > 터미널 서비스 > 원격 데스크톱 세션 호스트 > 보안

Step 3) [클라이언트 연결 암호화 수준 설정] > [암호화 수준]을 클라이언트 호환 가능으로 설정



[암호화 수준 설정]

※ 원격 데스크톱 서비스가 필요한 경우 추가 보완 대책

1. 관리자 이외의 일반 사용자의 터미널 서비스 접속을 허용하지 않음
2. 방화벽에서 원격 데스크톱 서비스 포트의 사용을 관리자 컴퓨터의 IP로 제한

W-29 (중)	Windows 서버 > 2. 서비스 관리
	불필요한 SNMP 서비스 구동 점검
개요	
점검 내용	SNMP 서비스 구동 여부 점검
점검 목적	취약한 SNMP 서비스를 비활성화하여 시스템의 주요 정보 유출 및 불법 수정을 방지하기 위함
보안 위협	취약한 SNMP 서비스를 사용하는 경우 서비스 거부 공격(DoS, DDoS), 버퍼 오버플로우, 비인가 접속 등의 공격 위험이 존재함
참고	※ SNMP : SNMP(Simple Network Management Protocol)는 MIB(Management Information Base)에 기반을 둔 네트워크망을 관리하기 위한 목적으로 만들어진 프로토콜로, 간단한 명령으로 원격 시스템의 CPU 정보에서부터, 인터페이스별 트래픽량 등 여러 가지 정보를 확인 가능 ※ 관련 점검항목: W-30(중), W-31(중)
점검 대상 및 판단 기준	
대상	Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : SNMP 서비스를 사용하지 않는 경우 또는 Community String을 설정하여 SNMP 서비스를 사용하는 경우
	취약 : 불필요하게 SNMP 서비스를 사용하는 경우
조치 방법	불필요 시 서비스 중지/사용 안 함
조치 시 영향	NMS 또는, 별도의 툴에서 SNMP 서비스를 이용하여 서버를 모니터링 하는 경우, 통신하고자 하는 Server/Client에 모두 같은 Community String을 사용해야 함(서비스 > SNMP > 등록 정보 > 종속성 참고) NMS(Network Management System): 네트워크 관리 시스템

점검 및 조치 사례

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 불필요 시 해당 서비스 중지

시작 > 제어판 > 관리 도구 > 서비스 > SNMP Service(또는, SNMP 서비스) > 속성에서 “시작 유형”을 “사용 안 함”으로 설정한 후, SNMP 서비스 중지



[SNMP 서비스 사용 안 함 설정]

02. Windows 서버

W-30 (중)	Windows 서버 > 2. 서비스 관리
	SNMP Community String 복잡성 설정
개요	
점검 내용	SNMP 서비스 Community String 적절성 점검
점검 목적	SNMP에서 일종의 비밀번호로 사용하는 Community String을 유추할 수 없는 복잡한 값으로 변경하여 불필요한 시스템 정보 노출을 차단하기 위함
보안 위협	Community String을 변경하지 않고 public, private 등 기본 설정값으로 사용하는 경우, 기본 Community String 값을 통한 시스템의 주요 정보 및 설정 상태가 비인가자에게 노출될 수 있는 위험이 존재함
참고	※ 관련 점검항목: W-29(중), W-31(중)
점검 대상 및 판단 기준	
대상	2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : SNMP 서비스를 사용하지 않거나 Community String이 public, private 이 아닌 경우
	취약 : SNMP 서비스를 사용하며, Community String이 public, private인 경우
조치 방법	불필요 시 서비스 중지/사용 안 함, 사용 시 기본 Community String 변경
조치 시 영향	NMS 또는, 별도의 도구에서 SNMP 서비스를 이용하여 서버를 모니터링하는 경우, 통신하고자 하는 Server/Client에 모두 같은 Community String을 사용해야 함. (서비스 > SNMP > 등록 정보 > 종속성 참고)

점검 및 조치 사례

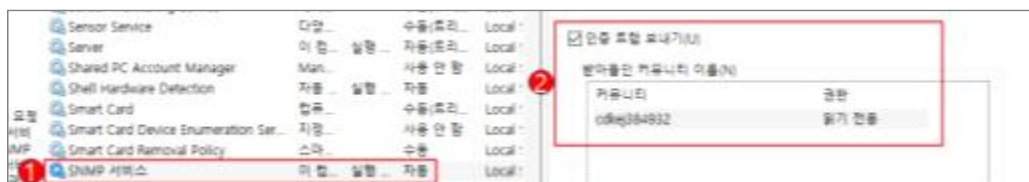
● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 서비스 > SNMP Service(또는, SNMP 서비스) > 속성 > 보안 > [인증 트랩 보내기] > [추가]

Step 2) Community String을 읽기 전용으로 설정 후 public/private이 아닌 이름을 추가

Step 3) 불필요 시 해당 서비스 중지

시작 > 실행 > SERVICES.MSC > SNMP Service(또는, SNMP 서비스) > 속성 [일반] 탭에서 “시작 유형”을 “사용 안 함”으로 설정한 후, SNMP 서비스 중지



[SNMP Community String 설정]

W-31 (중)	Windows 서버 > 2. 서비스 관리
	SNMP Access Control 설정
개요	
점검 내용	SNMP 패킷 Access Control(접근 제어) 설정 여부 점검
점검 목적	SNMP 트래픽에 대한 Access Control 설정을 적용하여 내부 네트워크로부터의 악의적인 공격을 차단하기 위함
보안 위협	SNMP Access Control 설정을 적용하지 않아 인증되지 않은 내부 서버로부터의 SNMP 트래픽을 차단하지 않을 경우, 장치 구성 변경, 라우팅 테이블 조작, 악의적인 TFTP 서버 구동 등의 SNMP 공격에 노출될 위험이 존재함
참고	※ 관련 점검항목: W-29(중), W-30(중)
점검 대상 및 판단 기준	
대상	Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : SNMP 서비스를 사용하지 않거나 특정 호스트로부터 SNMP 패킷 받아들이기가 설정된 경우
	취약 : 모든 호스트로부터 SNMP 패킷 받아들이기가 설정된 경우
조치 방법	불필요 시 서비스 중지/사용 안 함, 사용 시 SNMP 패킷 수령 호스트 지정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 서비스 > SNMP Service(또는, SNMP 서비스) > 속성 > 보안

Step 2) “인증 트랩 보내기” 및 “다음 호스트로부터 SNMP 패킷 받아들이기” 선택

Step 3) SNMP 호스트 등록



[SNMP 보안 설정]

02. Windows 서버

W-32 (중)	Windows 서버 > 2. 서비스 관리
	DNS 서비스 구동 점검
개요	
점검 내용	DNS 서비스의 동적 업데이트 설정 여부 점검
점검 목적	DNS 동적 업데이트를 비활성화함으로 신뢰할 수 없는 원본으로부터 업데이트를 받아들이는 위험을 차단하기 위함
보안 위험	DNS 서버에서 동적 업데이트를 사용할 경우 악의적인 사용자에게 의해 신뢰할 수 없는 데이터가 받아들여질 위험이 존재함
참고	※ 동적 업데이트 : DNS 정보에 변경 사항이 있을 때마다 DNS 클라이언트 컴퓨터가 자신의 리소스 레코드(zone 파일)를 DNS 서버에 자동으로 업데이트하는 기능으로 영역 레코드 수동 관리 작업을 줄일 수 있음
점검 대상 및 판단 기준	
대상	Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : DNS 서비스를 사용하지 않거나 동적 업데이트 “없음(아니오)”으로 설정된 경우
	취약 : 서비스를 사용하며 동적 업데이트가 설정된 경우
조치 방법	DNS 서비스의 동적 업데이트 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > DNS > 각 조회 영역 > 해당 영역 > 속성 > 일반

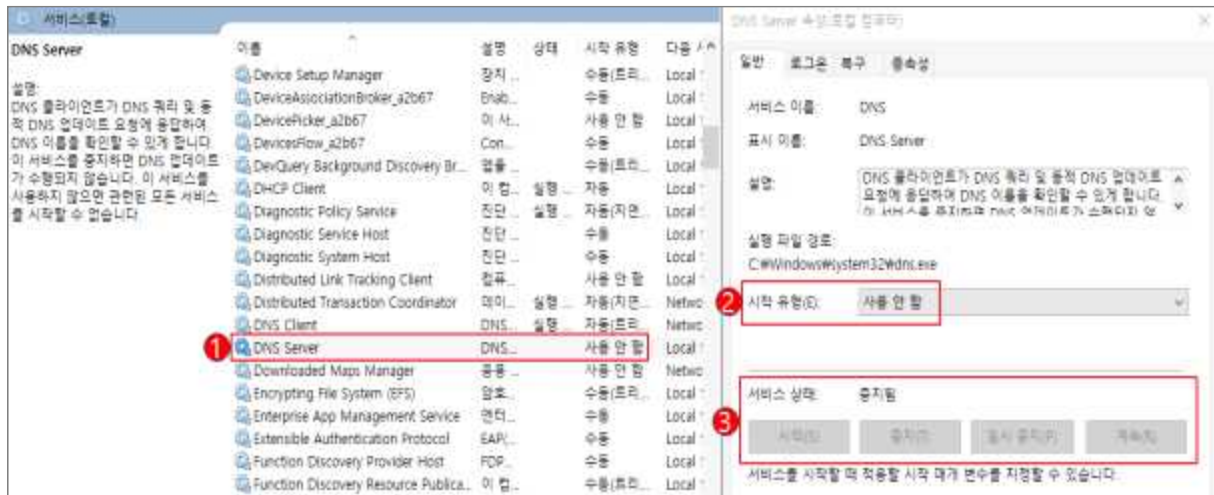
Step 2) 동적 업데이트 → 없음 (또는 아니오) 선택



[동적 업데이트 없음 설정]

Step 3) 불필요 시 해당 서비스 중지

시작 > 제어판 > 관리 도구 > 서비스 > DNS Server > 속성 [일반] 탭에서 "시작 유형"을 "사용 안 함"으로 설정한 후, DNS Server 서비스 중지



[DNS Server 사용 안 함 설정]

02. Windows 서버

W-33 (하)	Windows 서버 > 2. 서비스 관리
	HTTP/FTP/SMTP 배너 차단
개요	
점검 내용	HTTP/FTP/SMTP 서비스 배너 차단 적용 여부 점검
점검 목적	HTTP/FTP/SMTP 서비스 접속 배너를 통한 불필요한 정보 노출을 방지하기 위함
보안 위협	서비스 접속 배너가 차단되지 않는 경우 임의의 사용자가 HTTP, FTP, SMTP 접속 시도 시 노출되는 접속 배너 정보를 수집하여 악의적인 공격에 이용할 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : HTTP, FTP, SMTP 접속 시 배너 정보가 보이지 않는 경우
	취약 : HTTP, FTP, SMTP 접속 시 배너 정보가 보이는 경우
조치 방법	사용하지 않는 경우 IIS 서비스 중지/사용 안 함, 사용 시 속성값 수정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● HTTP

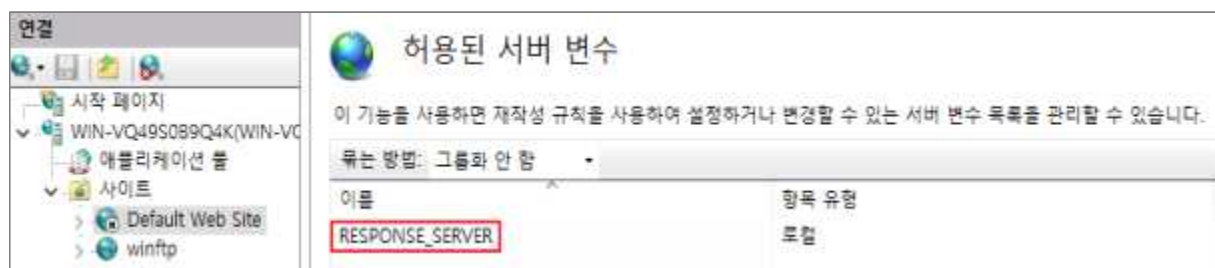
[Server 헤더 제거]

Step 1) Microsoft 다운로드 센터에서 URL Rewrite 다운로드 후 설치

<https://www.iis.net/downloads/microsoft/url-rewrite>

Step 2) 제어판 > 관리 도구 > IIS(인터넷 정보 서비스) 관리자 > 해당 웹 사이트 > [URL 재작성]

Step 3) 작업 탭 > [서버 값 관리 - 서버 변수 보기...] > 서버 변수 이름 추가



[서버 변수 추가]

Step 4) [URL 재작성] > 작업 탭 > [규칙 추가...] > 아웃바운드 규칙 > 빈 규칙 > 다음 사항 적용

- 이름(N): Remove Server
- 검색 범위: 서버 변수
- 서버 변수 이름: RESPONSE_SERVER
- 패턴(T): .*

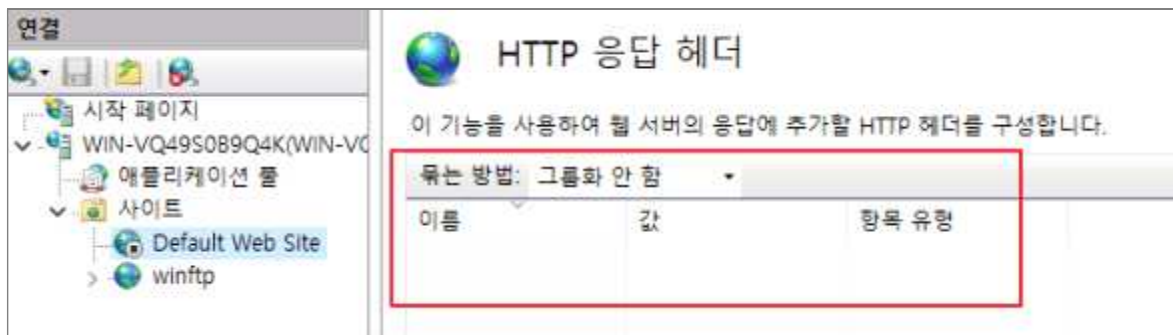


[아웃바운드 규칙 추가]

[X-Powered-By 헤더 제거]

Step 1) 제어판 > 관리 도구 > IIS(인터넷 정보 서비스) 관리자 > 해당 웹 사이트 > [HTTP 응답 헤더]

Step 2) [X-Powered-By] 설정 제거



[X-Powered-By 헤더 제거]

● FTP

Step 1) IIS(인터넷 정보 서비스) 관리자 > FTP 메시지 > 기본 배너 숨기기 설정



[FTP 기본 배너 숨기기 설정]

● SMTP

Step 1) 시작 > 실행 > cmd > adsutil.vbs 파일이 있는 디렉터리로 이동

- 명령어: `cd C:\inetpub\AdminScripts`

- adsutil.vbs를 사용하기 위해 서버 관리자에서 역할 추가 필요 → "웹 서버(IIS) > 관리 도구 > IIS 6 관리 호환성 > IIS 6 스크립팅 도구" 설치 필요

Step 2) IIS에서 서비스 중인 SMTP 서비스 목록 확인

- 명령어: `cscript adsutil.vbs enum /p smtpsvc`

Step 3) SMTP 서비스에 connectresponse 속성 값에서 배너 문구 수정

- 명령어: `cscript adsutil.vbs set smtpsvc/1/connectresponse "Banner Text"`

Step 4) SMTP 서비스 재시작

- 명령어: `net stop smtpsvc` (중지)

- 명령어: `net start smtpsvc` (시작)

W-34 (중)	Windows 서버 > 2. 서비스 관리
	Telnet 서비스 비활성화
개요	
점검 내용	Telnet 서비스 활성화 및 취약한 인증 사용 여부 점검
점검 목적	취약 프로토콜인 Telnet 서비스의 사용을 원칙적으로 금지하고, 부득이 이용할 경우 네트워크상으로 비밀번호를 전송하지 않는 NTLM 인증을 사용하도록 하여 인증 정보의 노출을 차단하기 위함
보안 위협	Telnet 서비스는 평문으로 데이터를 송수신하기 때문에 비밀번호 방식으로 인증을 수행할 경우 ID 및 비밀번호가 외부로 노출될 위험이 존재함
참고	※ Windows 서버의 Telnet 서비스의 두 가지 인증 방법 • NTLM 인증: 암호를 전송하지 않고 negotiate/challenge/response 절차로 인증 수행 • Password 인증: 관리자 및 Telnet Clients 그룹에 포함된 ID/PW로 인증 수행 ※ Windows 2016 이상 버전에서는 보안상 이슈로 인해 Telnet 서버 설치 제공하지 않음
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012
판단 기준	양호 : Telnet 서비스가 구동되어 있지 않거나 인증 방법이 NTLM인 경우
	취약 : Telnet 서비스가 구동되어 있으며 인증 방법이 NTLM이 아닌 경우
조치 방법	불필요 시 서비스 중지/사용 안 함 설정, 사용 시 인증 방법으로 NTLM만 사용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 시작 > 설정 > 제어판 > 관리 도구 > 텔넷 서버 설정

Step 2) NTLM 인증 방식만 사용

● Windows 2003, 2008, 2012

Step 1) 시작 > 실행 > cmd > tlntadmn config

Step 2) tlntadmn config sec = +NTLM -passwd (passwd 인증 방식을 제외하고 NTLM 방식만 사용)

Step 3) 불필요 시 해당 서비스 중지

시작 > 실행 > SERVICES.MSC > Telnet > 속성 [일반] 탭에서 "시작 유형"을 "사용 안 함"으로 설정한 후 Telnet 서비스 중지

W-35 (중)	Windows 서버 > 2. 서비스 관리
	불필요한 ODBC/OLE-DB 데이터 소스와 드라이브 제거
개요	
점검 내용	불필요한 ODBC/OLE-DB 데이터 소스와 드라이브 제거 여부 점검
점검 목적	불필요한 데이터 소스 및 드라이버를 ODBC 데이터 소스 관리자 도구를 이용해 제거하여 비인가자에 의한 데이터베이스 접속 및 자료 유출을 차단하기 위함
보안 위협	불필요한 ODBC/OLE-DB 데이터 소스를 통한 비인가자에 의한 데이터베이스 접속 및 자료 유출 이 존재함
참고	※ 특정 샘플 응용프로그램은 샘플 데이터베이스를 위해 ODBC 데이터 소스를 설치하거나 불필요한 ODBC/OLE-DB 데이터베이스 드라이버를 설치하므로 불필요한 데이터 소스나 드라이버는 ODBC 데이터 소스 관리자 도구를 이용해서 제거하는 것이 바람직함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 시스템 DSN 부분의 데이터 소스를 현재 사용하고 있는 경우
	취약 : 시스템 DSN 부분의 데이터 소스를 현재 사용하고 있지 않은 경우
조치 방법	사용하지 않는 불필요한 ODBC 데이터 소스 제거
조치 시 영향	응용프로그램에서 사용할 경우 양호

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 설정 > 제어판 > 데이터 원본(ODBC) > 시스템 DSN > 해당 드라이브 클릭

Step 2) 사용하지 않는 데이터 소스 제거

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > ODBC 데이터 원본 > 시스템 DSN > 해당 드라이브 클릭

Step 2) 사용하지 않는 데이터 소스 제거



[불필요 ODBC 데이터 소스 확인 및 제거]

W-36 (중)	Windows 서버 > 2. 서비스 관리
	원격터미널 접속 타임아웃 설정
개요	
점검 내용	원격터미널 접속 Timeout 설정 여부 점검
점검 목적	조직에서 부득이 원격터미널 접속을 허용해야 할 경우, 원격터미널 접속 후 일정 시간 동안 이벤트가 발생하지 않은 호스트의 접속을 차단하여 비인가자의 불필요한 접근을 차단하고 정보의 노출을 방지하기 위함
보안 위협	접속 Timeout 값이 설정되지 않으면 유휴 시간 내 비인가자의 시스템 접근으로 인해 불필요한 내부 정보의 노출 위험이 존재함
참고	※ 기반시설 시스템에서 원격터미널 서비스의 이용은 원칙적으로 금지하나, 부득이하게 해당 기능을 활용해야 하는 경우 접속 Timeout 설정 등의 보안 설정을 적용해야 함
점검 대상 및 판단 기준	
대상	Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 원격 제어 시 Timeout 제어 설정을 30분 이하로 설정한 경우
	취약 : 원격 제어 시 Timeout 제어 설정을 적용하지 않거나 30분 초과로 설정한 경우
조치 방법	Timeout 제어 설정 적용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2000, 2003, 2008

Step 1) 시작 > 실행 > 열기 > TSCC.MSC 실행(Windows 2008은 TSConfig.MC)

Step 2) RDP-Tcp connection에서 우클릭 > 속성 실행

Step 3) [세션] 탭에서 사용자 설정 무시(Override user settings)를 적용하고 유휴 시 세션이 끊어지도록 “유휴 세션 제한 시간”을 “30분” 이하로 설정

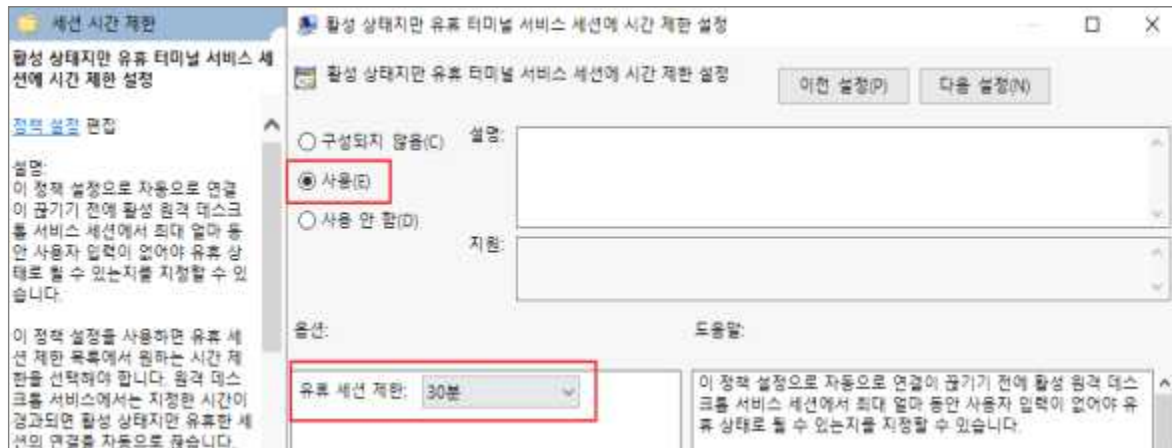
02. Windows 서버

● Windows 2012, 2016, 2019, 2022

Step 1) 시작 > 실행 > GPEDIT.MSC(로컬 그룹 정책 편집기)

Step 2) 컴퓨터 구성 > 관리 템플릿 > 터미널 서비스 > 원격 데스크톱 세션 호스트 > 세션 시간 제한 >

Step 3) [활성 상태지만 유향 터미널 서비스 세션에 시간 제한 설정] > [유향 세션 제한]을 30분 이하로 설정



[유향 세션 제한 설정]

W-37 (중)	Windows 서버 > 2. 서비스 관리
	예약된 작업에 의심스러운 명령이 등록되어 있는지 점검
개요	
점검 내용	예약된 작업에 의심스러운 명령의 등록 여부 점검
점검 목적	외부 무단 침입 시 설정될 수 있는 불필요한 예약 작업의 등록 여부를 확인하기 위함
보안 위협	일정 시간마다 미리 설정해둔 프로그램을 실행할 수 있는 예약된 작업은 시작 프로그램과 더불어서 해킹과 트로이목마, 백도어를 설치하여 공격하기 좋은 경로로 사용될 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 불필요한 명령어나 파일 등 주기적인 예약 작업의 존재 여부를 주기적으로 점검하고 제거한 경우
	취약 : 불필요한 명령어나 파일 등 주기적인 예약 작업의 존재 여부를 주기적으로 점검하지 않거나, 불필요한 작업을 제거하지 않은 경우
조치 방법	예약 작업에 대한 주기적인 확인
조치 시 영향	예약 작업을 잘못 삭제하는 경우 관련된 작업이 실행되지 않을 수 있음

점검 및 조치 사례

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 설정 > 제어판 > 예약된 작업 확인

Step 2) 등록된 예약 작업을 선택하여 상세 내역 확인

Step 3) 불필요한 작업 존재 시 삭제

실행 중인 작업을 현재 사용하고 완료되지 않은 작업입니다. 요약: 총 67			
작업 이름	다음 실행 시간	트리거	위치
MicrosoftEdgeUpdateTaskMachin...	2024-07-17 오후 10:58...	매일 오후 11:58에 - 트...	W
Data Integrity Check And Scan	2024-07-17 오후 11:51...	여러 개의 트리거가 장...	WMicrosoftWindowsW...
Consolidator	2024-07-18 오전 12:00...	2004-01-02 오전 12:00...	WMicrosoftWindowsW...
Schedule Scan	2024-07-17 오후 11:49...	2019-01-01 오후 12:00...	WMicrosoftWindowsW...
SpeechModelDownloadTask	2024-07-18 오전 2:25...	2004-01-01 오전 12:00...	WMicrosoftWindowsW...
MicrosoftEdgeUpdateTaskMachin...	2024-07-18 오전 12:28...	여러 개의 트리거가 장...	W
RefreshCache	2024-07-17 오후 11:54...	여러 개의 트리거가 장...	WMicrosoftWindowsW...
QueueReporting	2024-07-18 오전 1:11...	여러 개의 트리거가 장...	WMicrosoftWindowsW...

[불필요한 작업 제거]

※ 2008, 2012, 2016, 2019 는 제어판 > 관리 도구 > 작업 스케줄러에서 확인

02. Windows 서버

W-38 (상)	Windows 서버 > 3. 패치 관리
	주기적 보안 패치 및 벤더 권고사항 적용
개요	
점검 내용	최신 보안 패치 적용 여부 점검
점검 목적	최신 보안 패치를 설치하여 시스템 및 응용프로그램의 취약성을 제거하기 위함
보안 위협	최신 보안 패치가 즉시 적용되지 않으면 알려진 취약성으로 인한 시스템 공격 위험이 존재함
참고	※ 보안 패치보다 취약성을 이용한 공격 도구가 먼저 출현할 수 있으므로 보안 패치는 발표 후 가능한 빨리 설치할 것을 권장함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 패치 절차를 수립하여 주기적으로 패치를 확인 및 설치하는 경우
	취약 : 패치 절차가 수립되어 있지 않거나 주기적으로 패치를 설치하지 않는 경우
조치 방법	주기적인 보안 패치 확인 및 설치 적용
조치 시 영향	설치 후 시스템 재시작이 필요한 경우가 존재하며 설치에 따른 영향도 검사가 필요함

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

[수동 HOT FIX 적용]

Step 1) 패치 리스트를 조회하여, 서버에 필요한 패치를 선별하여 수동으로 설치함.

<https://technet.microsoft.com/ko-kr/security/>

<https://msrc.microsoft.com/update-guide>

[자동 HOT FIX 적용]

Step 1) Windows 자동업데이트 기능을 이용한 설치

제어판 > windows update

W-39 (상)	Windows 서버 > 3. 패치 관리
	백신 프로그램 업데이트
개요	
점검 내용	사용 백신 프로그램의 최신 업데이트 여부 점검
점검 목적	백신 프로그램의 최신 업데이트 상태를 유지하기 위함
보안 위협	백신 프로그램이 지속적, 주기적으로 업데이트되지 않으면 계속되는 신종 바이러스의 출현으로 인한 시스템 공격 위험이 존재함
참고	※ 네트워크망이 격리된 기반 보호 시설의 경우, 시스템에 설치된 백신 프로그램의 최신 업데이트 상태 유지를 위해 적절한 업데이트 절차 및 적용 방법 수립이 필요함 ※ 관련 점검항목 : W-45(상)
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 바이러스 백신 프로그램의 최신 엔진 업데이트가 설치되어 있거나, 망 격리 환경의 경우 백신 업데이트를 위한 절차 및 적용 방법이 수립된 경우
	취약 : 바이러스 백신 프로그램의 최신 엔진 업데이트가 설치되어 있지 않거나, 망 격리 환경의 경우 백신 업데이트를 위한 절차 및 적용 방법이 수립되지 않은 경우
조치 방법	백신 프로그램 환경설정 메뉴를 통해 DB 및 엔진의 최신 업데이트를 하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 긴급한 경우 수시로 업데이트 진행

(백신 프로그램 종류마다 다소 차이는 있으나 매주 업데이트가 진행됨)

Step 2) 정기적인 업데이트를 통해 검색엔진을 최신 버전으로 유지하고, 백신 프로그램 제조사에서 발표하는 정보 주시

Step 3) 백신 프로그램의 자동 업데이트 기능 이용 시 온라인을 통해 변동 사항을 자동으로 업데이트하여 알 수 있음

02. Windows 서버

W-40 (중)	Windows 서버 > 4. 로그 관리
	정책에 따른 시스템 로깅 설정
개요	
점검 내용	시스템 로깅 설정 여부 및 적절성 점검
점검 목적	적절한 로깅 설정으로 유사시 책임 추적을 위한 로그를 확보하기 위함
보안 위협	감사 설정이 구성되어 있지 않거나 감사 설정 수준이 너무 낮은 경우 보안 관련 문제 발생 시 원인을 파악하기 어려우며 법적 대응을 위한 충분한 증거 확보가 어려운 위험이 존재함
참고	※ 감사 정책을 과도하게 설정할 경우, 보안 로그에 불필요한 항목이 많이 기록되므로 중요한 감사 항목 식별이 어려울 수 있으며, 시스템 성능에도 심각한 영향을 줄 수 있으므로 법적 요구 사항과 조직의 정책에 따라 꼭 필요한 로그를 남기도록 설정해야 함 ※ Windows 시스템은 보안 로그가 가득 차게 되는 경우 가장 오래된 감사 항목이 덮어 씌워짐
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 감사 정책 권고 기준에 따라 감사 설정이 되어 있는 경우
	취약 : 감사 정책 권고 기준에 따라 감사 설정이 되어 있지 않은 경우
조치 방법	이벤트에 대한 감사 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 프로그램 > 관리 도구 > 도메인 사용자 관리자 > 정책 > 감사

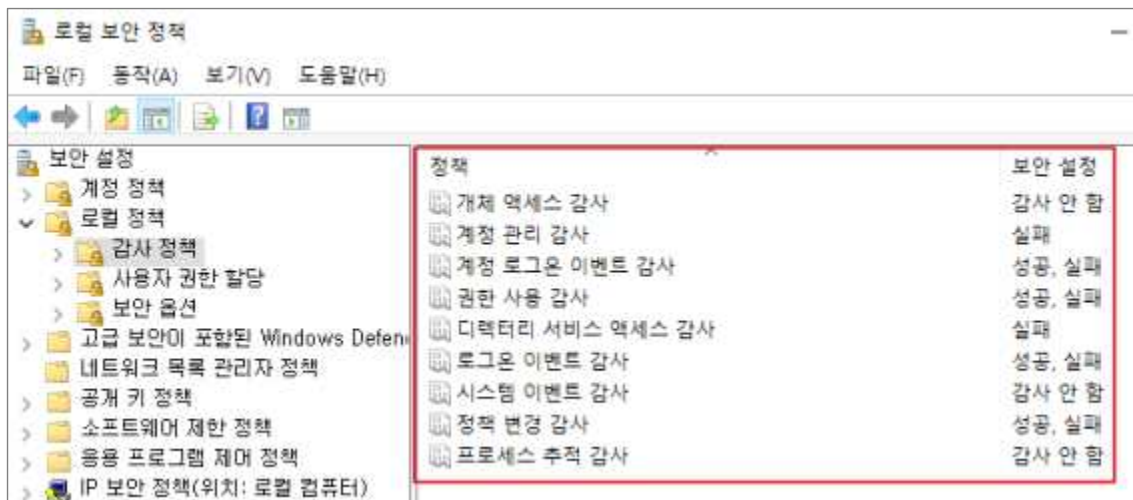
- 로그온 및 로그오프, 보안 정책 바꾸기: 성공/실패 감사
- 사용자 권한 사용, 사용자 및 그룹 관리: 실패 감사

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 감사 정책

<감사 정책 권고 기준>

- 계정 관리: 실패 감사
- 계정 로그인 이벤트: 성공/실패 감사
- 권한 사용: 성공/실패 감사
- 디렉터리 서비스 액세스: 실패 감사
- 로그인 이벤트: 성공/실패 감사
- 정책 변경: 성공/실패 감사



[감사 정책 설정]

W-41 (중)	Windows 서버 > 4. 로그 관리
	NTP 및 시각 동기화 설정
개요	
점검 내용	NTP 및 시각 동기화 설정 여부 점검
점검 목적	안전하고 승인된 Windows 시간 서비스 또는 자체 구축한 NTP 서버와 동기화하여 인증 및 감사하기 위함
보안 위험	시스템 간 시각 동기화 미흡으로 보안 사고 및 장애 발생 시 초기 대응이 불가능한 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : NTP 및 시각 동기화를 설정한 경우
	취약 : NTP 및 시각 동기화를 설정하지 않은 경우
조치 방법	NTP 및 시각 동기화 설정
조치 시 영향	일반적인 경우 영향 없음

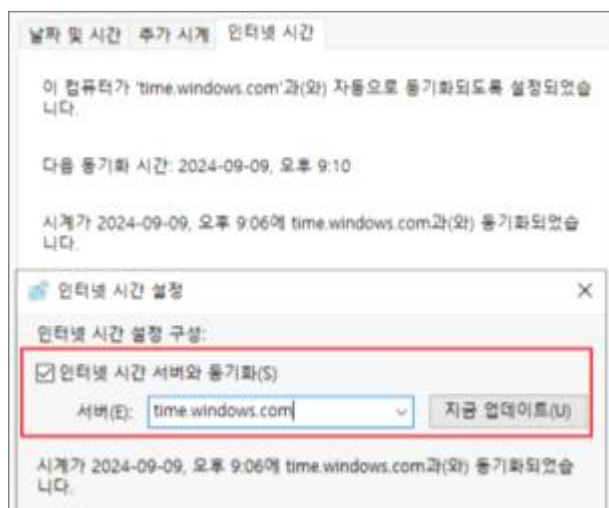
점검 및 조치 사례

- Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

[인터넷 동기화 설정 시]

Step 1) 제어판 > 시계 및 국가 > 날짜 및 시간 > 인터넷 시간 > 설정 변경 > 인터넷 시간 서버와 동기화

Step 2) 신뢰할 수 있는 NTP 서버 입력 후 적용



[NTP 설정 및 동기화]

[내부 NTP 서버 사용 시]

Step 1) 시간 동기화 정보 확인 (Client)

CMD > w32tm /dumpreg /subkey:parameters

```
C:\Windows\system32>w32tm /dumpreg /subkey:parameters
```

값 이름	값 종류	값 데이터
NtpServer	REG_SZ	time.windows.com,0x9
ServiceDll	REG_EXPAND_SZ	%systemroot%\system32\w32time.dll
ServiceDllUnloadOnStop	REG_DWORD	1
ServiceMain	REG_SZ	SvchostEntry_W32Time
Type	REG_SZ	NTP

Step 2) 내부 NTP서버로 시간동기화 설정 (Client)

(설정) CMD > w32tm /config /syncfromflags:manual /manualpeerlist:{NTP서버 IP or 도메인} /update

(적용 확인) CMD > w32tm /dumpreg /subkey:parameters

```
C:\Windows\system32>w32tm /dumpreg /subkey:parameters
```

값 이름	값 종류	값 데이터
NtpServer	REG_SZ	192.168.238.128,0x9
ServiceDll	REG_EXPAND_SZ	%systemroot%\system32\w32time.dll
ServiceDllUnloadOnStop	REG_DWORD	1
ServiceMain	REG_SZ	SvchostEntry_W32Time
Type	REG_SZ	NTP

※ Client에서 동기화 설정 후 ‘SpecialPollInterval’ ‘MaxPosPhaseCorrection’ 설정에 따라 주기적으로 자동으로 동기화가 적용되지만 NTP Server에서 다음 명령어로 즉시 적용 가능함.

CMD > w32tm /resync

```
C:\Windows\system32>w32tm /resync
로컬 컴퓨터에 다시 동기화 명령을 보내는 중
명령이 성공적으로 완료되었습니다.
```

Step 1) 동기화 시간차 확인

CMD > w32tm /stripchart /dataonly /computer:{NTP서버 IP or 도메인}

```
C:\Windows\system32>w32tm /stripchart /dataonly /computer:192.168.238.128
192.168.238.128[192.168.238.128:123] 추적 중
현재 시간은 2024-12-02 오후 6:56:30입니다.
18:56:30, +00.0425597s
18:56:32, +00.0426009s
18:56:34, +00.0425101s
18:56:36, +00.0425450s
18:56:38, +00.0425516s
18:56:40, +00.0425658s
```

02. Windows 서버

W-42 (하)	Windows 서버 > 4. 로그 관리
	이벤트 로그 관리 설정
개요	
점검 내용	이벤트 로그 파일 용량 및 보관 기간 설정 점검
점검 목적	유사시 책임추적을 위해 주요 이벤트가 누락 되지 않도록 이벤트 로그 파일의 크기 및 보관 기간을 적절하게 유지하기 위함
보안 위협	이벤트 로그 파일의 크기가 충분하지 않으면 중요 로그가 저장되지 않을 위험이 있으며, 최대 보존 크기를 초과하는 경우 자동으로 덮어쓰으로써 중요 로그의 손실 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 최대 로그 크기 “10,240KB 이상”으로 설정, “90일 이후 이벤트 덮어쓰기”를 설정한 경우
	취약 : 최대 로그 크기 “10,240KB 미만”으로 설정, 이벤트 덮어쓰기 기간이 “90일 이하로 설정된 경우
조치 방법	최대 로그 크기 “10,240KB”, “90일 이후 이벤트 덮어쓰기” 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 이벤트 뷰어 > 해당 로그 > 속성 > 일반

Step 2) 최대 로그 크기 → 10240KB

최대 로그 크기에 도달할 때: 다음보다 오래된 이벤트 덮어쓰기 → 90일

☒ 로깅 사용(E)
 최대 로그 크기(KB)(X): 10240
 최대 이벤트 로그 크기에 도달할 때:
☐ 필요한 경우 이벤트 덮어쓰기(가장 오래된 이벤트 먼저)
☒ 로그가 꽉 차면 로그 보관. 이벤트를 덮어쓰지 않음(A)
☐ 이벤트 덮어쓰지 않음(수동으로 로그 지우기)(N)

[이벤트 로그 덮어쓰기 설정]

※ Windows 2008, 2012, 2016, 2019 서버의 경우 덮어쓰기 날짜 지정 불가능

W-43 (중)	Windows 서버 > 4. 로그 관리
	이벤트 로그 파일 접근 통제 설정
개요	
점검 내용	원격에서 로그 파일의 접근을 차단하기 위한 권한 적절성 점검
점검 목적	원격에서 로그 파일에 접근하는 것을 차단하여 로그 파일의 훼손 및 변조를 차단하기 위함
보안 위협	원격 익명 사용자의 시스템 로그 파일에 접근이 가능한 경우 '중요 시스템 로그' 파일 및 '응용프로그램 로그' 등 중요 보안 감사 정보의 변조·삭제·유출의 위험이 존재함
참고	※ 로그 디렉터리 기본 위치 • 시스템 로그 디렉터리: %systemroot%\system32\config • IIS 로그 디렉터리: %systemroot%\system32\LogFiles
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 로그 디렉터리의 접근 권한에 Everyone 권한이 없는 경우
	취약 : 로그 디렉터리의 접근 권한에 Everyone 권한이 있는 경우
조치 방법	로그 디렉터리의 접근 권한에 Everyone 제거
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012

Step 1) 탐색기 > 로그 디렉터리 > 속성 > 보안

Step 2) Everyone 권한 제거

● Windows 2016, 2019, 2022

Step 1) 탐색기 > 로그 디렉터리 > 속성 > 보안 > 고급

Step 2) Everyone 권한 제거

사용 권한 목록:				
유형	보안 주제	액세스	다음에서 상속됨	작동 대상
허용	TrustedInstaller	모든 권한	C:\Windows\System32\w	이 폴더 및 하위 폴더
허용	SYSTEM	모든 권한	C:\Windows\System32\w	이 폴더, 하위 폴더 및 파일
허용	Administrators (WIN-VQ4950B9Q4...	모든 권한	C:\Windows\System32\w	이 폴더, 하위 폴더 및 파일
허용	Users (WIN-VQ4950B9Q4K\Users)	읽기 및 실행	C:\Windows\System32\w	이 폴더, 하위 폴더 및 파일
허용	CREATOR OWNER	모든 권한	C:\Windows\System32\w	하위 폴더 및 파일만
허용	ALL APPLICATION PACKAGES	읽기 및 실행	C:\Windows\System32\w	이 폴더, 하위 폴더 및 파일
허용	ALL RESTRICTED APPLICATION PA...	읽기 및 실행	C:\Windows\System32\w	이 폴더, 하위 폴더 및 파일

[로그 디렉터리 권한 확인]

02. Windows 서버

W-44 (상)	Windows 서버 > 5. 보안 관리
	원격으로 액세스할 수 있는 레지스트리 경로
개요	
점검 내용	원격 레지스트리 서비스 사용 여부 점검
점검 목적	원격 레지스트리 서비스를 비활성화하여 레지스트리에 대한 원격 접근을 차단하기 위함
보안 위협	- 원격 레지스트리 서비스는 액세스에 대한 인증이 취약하여 관리자 계정 외 다른 계정들에도 원격 레지스트리 액세스를 허용할 우려가 있으며, 레지스트리에 대한 권한 설정이 잘못되어 있는 경우 원격에서 레지스트리를 통해 임의의 파일을 실행할 위험이 존재함 - 레지스트리 서비스의 장애는 전체 시스템에 영향을 줄 수 있어 서비스 거부 공격(DoS) 공격에 이용될 위험이 존재함
참고	※ 레지스트리: Windows를 실행하는데 필요한 모든 환경설정 데이터를 모아 두는 중앙 저장소 ※ 원격 레지스트리 서비스: 원격지에 있는 컴퓨터를 한곳에서 집중적으로 관리하기 위한 목적으로 원격 컴퓨터의 레지스트리에 접근할 수 있도록 하는 서비스
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : Remote Registry Service가 중지된 경우
	취약 : Remote Registry Service가 사용 중인 경우
조치 방법	불필요 시 서비스 중지 및 사용 안 함으로 설정
조치 시 영향	Remote Registry Service를 사용하는지 확인 필요 (서비스 > Remote Registry Service > 등록 정보 > 종속성 참고)

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 서비스 > Remote Registry > 속성

Step 2) 시작 유형을 “사용 안 함”으로 설정한 후 서비스 중지



[Remote Registry 사용 중지 설정]

W-45 (상)	Windows 서버 > 5. 보안 관리
	백신 프로그램 설치
개요	
점검 내용	시스템 내 백신 프로그램 설치 여부 점검
점검 목적	적절한 백신 프로그램을 설치하여 바이러스 감염 여부 진단, 치료 및 파일 보호를 통해 보안 사고를 예방하기 위함
보안 위협	백신 프로그램이 설치되지 않으면 웜, 트로이목마 등의 악성 바이러스로 인한 시스템 피해 위험이 존재함
참고	※ 웜 : 악의적인 목적을 가지고 자기 자신을 복제해 전파하며 주로 네트워크 공유 폴더나 메일로 전파됨 ※ 트로이목마 : 고의로 악의적 목적이 있는 파일, 주로 다른 악성 코드나 위장된 프로그램으로 전파되거나 인터넷을 통해 다운로드 됨 ※ 관련 점검항목 : W-39(상)
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 바이러스 백신 프로그램이 설치된 경우
	취약 : 바이러스 백신 프로그램이 설치되어 있지 않은 경우
조치 방법	백신 프로그램 설치
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

※ 백신 프로그램에 대한 인지도, 효과성 등을 검토하여 설치할 수 있음

02. Windows 서버

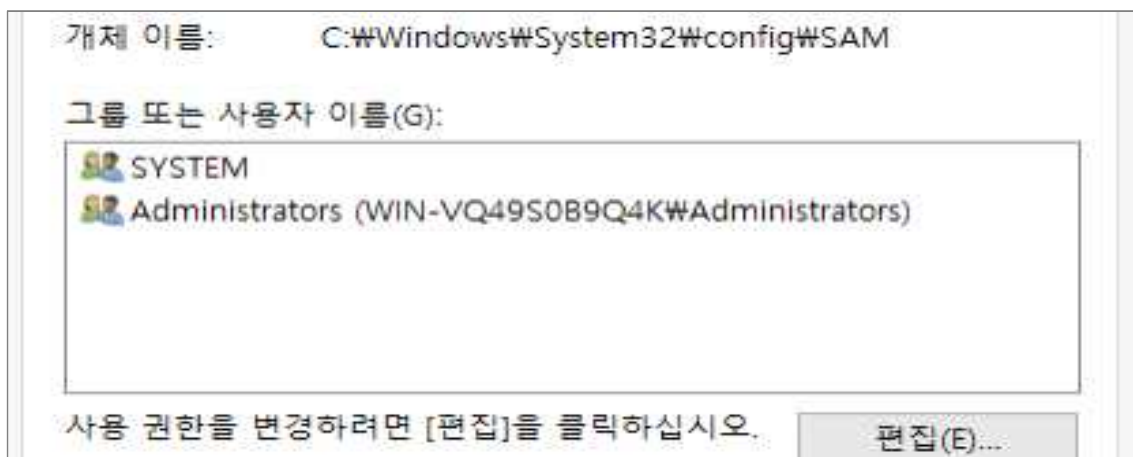
W-46 (상)	Windows 서버 > 5. 보안 관리
	SAM 파일 접근 통제 설정
개요	
점검 내용	SAM 파일 접근 통제 설정 여부 점검
점검 목적	Administrator 및 System 그룹만 SAM 파일에 접근할 수 있도록 제한하여 악의적인 계정 정보 유출을 차단하기 위함
보안 위협	SAM 파일이 노출될 경우 비밀번호 공격 시도로 인해 계정 및 비밀번호 데이터베이스 정보가 탈취될 위험이 존재함
참고	※ SAM(Security Account Manager) : 사용자와 그룹 계정의 비밀번호를 관리하고, LSA(Local Security Authority)를 통한 인증을 제공함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : SAM 파일 접근 권한에 Administrator, System 그룹만 모든 권한으로 설정된 경우
	취약 : SAM 파일 접근 권한에 Administrator, System 그룹 외 다른 그룹에 권한이 설정된 경우
조치 방법	SAM 파일 권한 확인 후 Administrator, System 그룹 외 다른 그룹에 설정된 권한 제거
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) %systemroot%\system32\config\SAM > 속성 > 보안

Step 2) Administrator, System 그룹 외 다른 사용자 및 그룹 권한 제거



[SAM 파일 권한 확인]

W-47 (하)	Windows 서버 > 5. 보안 관리
	화면 보호기 설정
개요	
점검 내용	시스템 화면보호기 설정 여부 점검
점검 목적	사용자가 일정 시간 동안 아무런 작업을 수행하지 않으면 자동으로 로그오프 되거나 워크스테이션이 잠기도록 설정하여, 유휴 시간 내 불법적인 시스템 접근을 차단하기 위함
보안 위협	화면보호기 설정을 하지 않으면 사용자가 자리를 비운 사이에 임의의 사용자가 해당 시스템에 접근하여 중요 정보를 유출하거나, 악의적인 행위를 통해 시스템 운영에 악영향을 미칠 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 화면 보호기를 설정하고 대기 시간이 10분 이하의 값으로 설정되어 있으며, 화면 보호기 해제를 위한 암호를 사용하는 경우
	취약 : 화면 보호기가 설정되지 않았거나 암호를 사용하지 않거나, 화면 보호기 대기 시간이 10분을 초과한 값으로 설정된 경우
조치 방법	화면 보호기 사용, 대기 시간 10분 이하, 해제를 위한 암호 사용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 바탕화면 > 등록 정보 > 화면 보호기

Step 2) “암호 사용” 설정 및 대기 시간 “10분” 이하로 설정

● Windows 2003

Step 1) 바탕화면 > 마우스 우클릭 > 속성 > 디스플레이 등록 정보 > [화면 보호기]

Step 2) "다시 시작할 때 암호로 보호" 설정 및 대기 시간 “10분” 이하로 설정

02. Windows 서버

● Windows 2008, 2012

Step 1) 제어판 > 디스플레이 > 화면 보호기 변경

Step 2) "다시 시작할 때 로그인 화면 표시" 설정 및 대기 시간 "10분" 이하로 설정

● Windows 2016, 2019, 2022

Step 1) 설정 > 개인 설정 > 잠금 화면 > 화면 보호기 설정

Step 2) "다시 시작할 때 로그인 화면 표시" 설정 및 대기 시간 "10분" 이하로 설정



[화면 보호기 설정]

W-48 (상)	Windows 서버 > 5. 보안 관리
	로그온하지 않고 시스템 종료 허용
개요	
점검 내용	비 로그인 사용자의 시스템 종료 허용 여부 점검
점검 목적	시스템 로그인 화면의 종료 버튼을 비활성화함으로써 허가되지 않은 사용자를 통한 불법적인 시스템 종료를 방지하고자 함
보안 위협	로그온 화면에 “시스템 종료” 버튼이 활성화되어 있으면 로그인을 하지 않고도 불법적인 시스템 종료가 가능하여 정상적인 서비스 운영에 영향을 줌
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “로그온하지 않고 시스템 종료 허용”이 “사용 안 함”으로 설정된 경우
	취약 : “로그온하지 않고 시스템 종료 허용”이 “사용”으로 설정된 경우
조치 방법	“시스템 종료: 로그인하지 않고 시스템 종료” 정책을 “사용 안 함” 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 제어판 > 관리 도구 > 레지스트리 편집기

Step 2) 다음의 레지스트리 값 추가 또는 변경

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\
ShutdownWithoutLogon = 0
```

● Windows 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) “로그온하지 않고 시스템 종료 허용”을 “사용 안 함”으로 설정

- Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “시스템 종료: 로그온하지 않고 시스템 종료 허용”을 “사용 안 함”으로 설정



[로그온하지 않고 시스템 종료 허용 사용 안 함 설정]

W-49 (상)	Windows 서버 > 5. 보안 관리
	원격 시스템에서 강제로 시스템 종료
개요	
점검 내용	원격 시스템 종료 정책 적절성 점검
점검 목적	원격에서 네트워크를 통하여 운영체제를 종료할 수 있는 사용자나 그룹을 설정하여 특정 사용자만 시스템 종료를 허용하기 위함
보안 위협	원격 시스템 강제 종료 설정이 부적절한 경우 서비스 거부 공격 등에 악용될 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “원격 시스템에서 강제로 시스템 종료” 정책에 “Administrators”만 존재하는 경우
	취약 : “원격 시스템에서 강제로 시스템 종료” 정책에 “Administrators” 외 다른 계정 및 그룹이 존재하는 경우
조치 방법	“원격 시스템에서 강제로 시스템 종료” 정책에 “Administrators” 외 다른 계정 및 그룹 제거
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 사용자 권한 할당

Step 2) “원격 시스템에서 강제로 시스템 종료” 정책에 Administrators 외 다른 계정 및 그룹 제거



[원격 시스템에서 강제 종료]

02. Windows 서버

W-50 (상)	Windows 서버 > 5. 보안 관리
	보안 감사를 로그 할 수 없는 경우 즉시 시스템 종료
개요	
점검 내용	‘보안 감사를 로그 할 수 없는 경우 즉시 시스템 종료’ 정책 설정 여부 점검
점검 목적	해당 정책을 비활성화함으로써 로그 용량 초과 등의 이유로 이벤트를 기록할 수 없는 경우, 해당 정책으로 인해 시스템이 비정상적으로 종료되는 것을 방지하기 위함
보안 위협	해당 정책이 활성화되어 있는 경우 악의적인 목적으로 시스템 종료를 유발하여 서비스 거부 공격에 악용될 수 있으며, 비정상적인 시스템 종료로 인해 시스템 및 데이터에 손상을 입힐 위험이 존재함
참고	※ 일반적으로 보안 감사 로그가 꽉 찼을 때 보안 로그에 대한 보존 방법이 [이벤트를 덮어쓰지 않음] 또는 [매일 이벤트 덮어쓰기]인 경우 이벤트가 로그 되지 않음. 보안 로그가 꽉 차고 기존 항목을 덮어쓸 수 없을 때 해당 정책을 사용하는 경우 다음과 같은 중지 오류가 출력됨 중지: C0000244 {감사 실패} 보안 감사를 만들려고 했으나 만들지 못했습니다. 복구하려면 관리자가 로그인하여 로그를 보관한 다음 로그를 지우고 이 옵션을 원하는 대로 다시 설정해야 합니다. 이 보안 설정을 다시 설정할 때까지는 보안 로그가 꽉 차지 않았더라도 Administrators 그룹의 구성원이 아니면 어떤 사용자도 시스템에 로그인할 수 없습니다.
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “보안 감사를 로그 할 수 없는 경우 즉시 시스템 종료” 정책이 “사용 안 함”으로 되어있는 경우
	취약 : “보안 감사를 로그 할 수 없는 경우 즉시 시스템 종료” 정책이 “사용”으로 되어있는 경우
조치 방법	“보안 감사를 로그 할 수 없는 경우 즉시 시스템 종료” 정책을 “사용 안 함”으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) “보안 감사를 로그 할 수 없는 경우 즉시 시스템 종료” 정책을 “사용 안 함”으로 설정

- Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “감사: 보안 감사를 로그할 수 없는 경우 즉시 시스템 종료” 정책을 “사용 안 함”으로 설정



[감사 정책 사용 안 함 설정]

02. Windows 서버

W-51 (상)	Windows 서버 > 5. 보안 관리
	SAM 계정과 공유의 익명 열거 허용 안 함
개요	
점검 내용	“SAM 계정과 공유의 익명 열거 허용 안 함” 정책 설정 여부 점검
점검 목적	익명 사용자에게 의한 악의적인 계정 정보 탈취를 방지하기 위함
보안 위협	Windows에서는 익명의 사용자가 도메인 계정(사용자, 컴퓨터 및 그룹)과 네트워크 공유 이름의 열거 작업을 수행할 수 있으므로 SAM(보안 계정 관리자) 계정과 공유의 익명 열거가 허용될 경우 악의적인 사용자가 계정 이름 목록을 확인하고 이 정보를 사용하여 암호를 추측하거나 사회 공학적 공격기법을 수행할 위험이 존재함
참고	※ 방화벽과 라우터에서 135~139(TCP, UDP) Port 차단을 통해 외부로부터의 위협을 차단함 ※ 네트워크 및 전화 접속 연결 > 로컬 영역 > 등록 정보 > 고급 > 고급 설정 > Microsoft 네트워크 파일 및 프린트 공유를 해제해야 함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “SAM 계정과 공유의 익명 열거 허용 안 함”이 “사용”으로 설정된 경우
	취약 : “SAM 계정과 공유의 익명 열거 허용 안 함”이 “사용 안 함”으로 설정된 경우
조치 방법	레지스트리 값 또는, 로컬 보안 정책 설정
조치 시 영향	Active Directory, Clustered system에서는 적용 시 영향 있음

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 제어판 > 관리 도구 > 레지스트리 편집기

HKLM\SYSTEM\CurrentControlSet\Control\LSA

Step 2) RestrictAnonymous 값을 “1”로 설정

● Windows 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) “익명의 연결에 추가적인 제한”에 “명백한 익명의 사용 권한이 없으면 액세스 제한” 선택

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) "네트워크 액세스 : SAM 계정과 공유의 익명 열거 허용 안 함"과 "네트워크 액세스 : SAM 계정의 익명 열거 허용 안 함"에 "사용" 선택



[익명 열거 허용 안 함 사용 설정]

02. Windows 서버

W-52 (상)	Windows 서버 > 5. 보안 관리
	Autologon 기능 제어
개요	
점검 내용	Autologon 기능 제어 설정 여부 점검
점검 목적	Autologon 기능을 사용하지 않도록 설정하여 시스템 계정 정보 노출을 차단하기 위함
보안 위협	Autologon 기능을 사용하면 침입자가 해킹 도구를 이용하여 레지스트리에 저장된 로그인 계정 및 비밀번호 정보 유출 위험이 존재함
참고	※ Autologon : 레지스트리에 암호화되어 저장된 대체 증명을 사용하여 자동으로 로그인하는 기능 ※ AutoAdminLogon 키가 없는 경우 기본값 비활성화
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : AutoAdminLogon 값이 없거나 0으로 설정된 경우
	취약 : AutoAdminLogon 값이 1로 설정된 경우
조치 방법	해당 레지스트리 값이 존재하는 경우 0으로 설정
조치 시 영향	반드시 자동 로그인을 사용하여야 할 경우를 제외하고는 일반적으로 영향 없음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 레지스트리 편집기

HKLM\SOFTWARE\Microsoft\WindowsNT\CurrentVersion\Winlogon

Step 2) “AutoAdminLogon” 값을 “0”으로 설정

Step 3) “Default Password” 존재 시 제거

이름	종류	데이터
(기본값)	REG_SZ	(값 설정 안 됨)
AutoRestartShell	REG_DWORD	0x00000001 (1)
Background	REG_SZ	0 0 0
CachedLogonsCount	REG_SZ	10
DebugServerCommand	REG_SZ	no
DefaultDomainName	REG_SZ	
DefaultUserName	REG_SZ	
DisableBackButton	REG_DWORD	0x00000001 (1)
DisableCAD	REG_DWORD	0x00000001 (1)
EnableSIHostIntegration	REG_DWORD	0x00000001 (1)
ForceUnlockLogon	REG_DWORD	0x00000000 (0)
LastLogOffEndTimePerfCounter	REG_QWORD	0x198060f0f5 (109528019189)
LegalNoticeCaption	REG_SZ	

[AutoAdminLogon 값 확인]

W-53 (상)	Windows 서버 > 5. 보안 관리
	이동식 미디어 포맷 및 꺼내기 허용
개요	
점검 내용	관리자 이외 NTFS 미디어 포맷 및 꺼내기 허용 여부 점검
점검 목적	이동식 미디어의 NTFS 포맷 및 꺼내기가 허용되는 사용자를 관리 권한자로 제한함으로써 관리 권한이 없는 사용자 및 비인가자에 의한 불법적인 이동식 미디어의 포맷 및 이동을 차단하기 위함
보안 위협	관리자 이외 사용자에게 해당 정책이 설정된 경우 비인가자에 의한 불법적인 매체 처리를 허용할 위험이 존재함
참고	※ 해당 보안 설정은 이동식 NTFS 미디어를 포맷하거나 꺼낼 수 있는 사용자를 결정하는 옵션으로 Administrators, Administrators 및 Power Users, Administrators 및 Interactive Users 그룹에 이 기능을 허용할 수 있음
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “이동식 미디어 포맷 및 꺼내기 허용” 정책이 “Administrators”로 되어있는 경우
	취약 : “이동식 미디어 포맷 및 꺼내기 허용” 정책이 “Administrators”로 되어있지 않은 경우
조치 방법	“이동식 NTFS 미디어 꺼내기 허용” 정책을 “Administrators”로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) “이동식 NTFS 미디어 꺼내기 허용” 정책을 “Administrators”로 설정

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “장치 : 이동식 미디어 포맷 및 꺼내기 허용” 정책을 “Administrators”로 설정



[이동식 미디어 포맷 및 꺼내기 허용]

02. Windows 서버

W-54 (중)	Windows 서버 > 5. 보안 관리
	Dos 공격 방어 레지스트리 설정
개요	
점검 내용	DoS 공격 방어 레지스트리 설정 여부 점검
점검 목적	TCP/IP 스택(Stack)을 강화하는 레지스트리 값 변경을 통하여 DoS 공격을 방어하기 위함
보안 위협	DoS 방어 레지스트리를 설정하지 않은 경우, DoS 공격에 의한 시스템 다운으로 서비스 제공이 중단될 위험이 존재함
참고	※ DoS(서비스 거부 공격) : 네트워크 사용자가 컴퓨터나 컴퓨터의 특정 서비스를 사용할 수 없도록 만들기 위한 네트워크 공격
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 아래 4가지 DoS 방어 레지스트리를 설정한 경우 • SynAttackProtect → 1이상 • EnableDeadGWDetect → 0 • KeepAliveTime → 300,000 • NoNameReleaseOnDemand → 1
	취약 : DoS 방어 레지스트리 값이 설정되어 있지 않은 경우
조치 방법	레지스트리 값을 추가 또는 수정
조치 시 영향	잘못된 값으로 설정할 경우 운영체제 재설치를 요구할 수 있음

점검 및 조치 사례

● Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 레지스트리 편집기

HKLM\System\CurrentControlSet\Services\Tcpip\Parameters\ 폴더

Step 2) 다음의 DoS 방어 레지스트리 값 추가 또는 변경

- SynAttackProtect = REG_DWORD 0(False) - > 1 이상
- EnableDeadGWDetect = REG_DWORD 1(True) - > 0
- KeepAliveTime = REG_DWORD 7,200,000(2시간) - > 300,000(5분)
- NoNameReleaseOnDemand = REG_DWORD 0(False) - > 1

W-55 (중)	Windows 서버 > 5. 보안 관리
	사용자가 프린터 드라이버를 설치할 수 없게 함
개요	
점검 내용	사용자의 프린터 드라이버 설치 차단 여부 점검
점검 목적	일반 사용자를 통한 프린터 드라이버 설치를 차단하여 의도하지 않은 시스템 손상을 방지하기 위함
보안 위협	서버에 프린터 드라이버를 설치하는 경우 악의적인 사용자가 고의로 잘못된 프린터 드라이버를 설치하여 컴퓨터를 손상할 수 있으며, 프린터 드라이버로 위장한 악성코드를 설치할 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “사용자가 프린터 드라이버를 설치할 수 없게 함” 정책이 “사용”인 경우
	취약 : “사용자가 프린터 드라이버를 설치할 수 없게 함” 정책이 “사용 안 함”인 경우
조치 방법	“사용자가 프린터 드라이버를 설치할 수 없게 함” 정책을 “사용”으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) “사용자가 프린터 드라이버를 설치할 수 없게 함” 정책을 “사용”으로 설정

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “장치: 사용자가 프린터 드라이버를 설치할 수 없게 함” 정책을 “사용”으로 설정



[장치: 사용자가 프린터 드라이버를 설치할 수 없게 함 적용]

02. Windows 서버

W-56 (중)	Windows 서버 > 5. 보안 관리
	SMB 세션 중단 관리 설정
개요	
점검 내용	Session 연결 중단 시 유희 시간 설정 여부 점검
점검 목적	Session이 중단되기 전에 SMB(서버 메시지 블록) Session에서 보내야 하는 연속 유희 시간을 결정하여 서비스 거부 공격 등에 악용되지 않도록 하기 위함
보안 위협	SMB Session에서는 서버 리소스를 사용하며, NULL Session 수가 많으면 서버 속도가 느려지거나 서버에 오류를 발생시킬 수 있으므로 공격자는 이를 악용하여 SMB Session을 반복 설정하여 서버의 SMB 서비스가 느려지거나 응답하지 않게 하여 서비스 거부 공격을 실행할 위험이 존재함
참고	※ Administrator는 해당 정책을 활성화하여 컴퓨터가 비활성 SMB Session을 중단하는 시점을 제어할 수 있으며, 클라이언트를 다시 시작하면 해당 Session은 자동으로 다시 연결됨. 해당 정책의 값을 0으로 설정하면 가능한 한 빨리 유희 Session 연결은 끊어지며, 최댓값은 99999(208일)로 사실상 정책 설정 해제를 의미함 ※ SMB(서버 메시지 블록): LAN이나 컴퓨터 간의 통신에서 데이터 송수신을 하기 위한 프로토콜
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : “로그온 시간이 만료되면 클라이언트 연결 끊기” 정책을 “사용”으로, “세션 연결을 중단하기 전에 필요한 유희 시간” 정책을 “15분” 이하로 설정한 경우
	취약 : “로그온 시간이 만료되면 클라이언트 연결 끊기” 정책이 “사용 안 함” 또는 “세션 연결을 중단하기 전에 필요한 유희 시간” 정책이 “15분” 초과로 설정한 경우
조치 방법	“로그인 시간이 만료되면 클라이언트 연결 끊기” 정책 “사용” 설정 “세션 연결을 중단하기 전에 필요한 유희 시간” 정책 “15분” 이하로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) “로그인 시간이 만료되면 클라이언트 연결 끊기” 정책 “사용” 설정

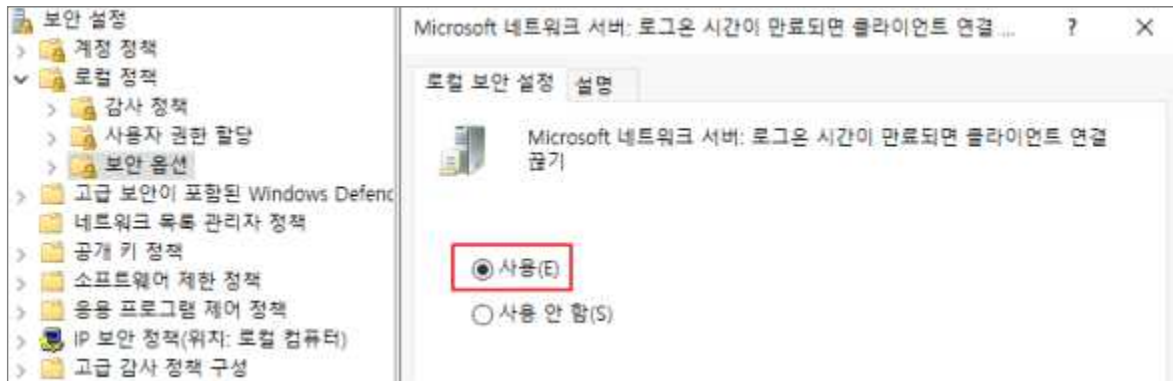
“세션 연결을 중단하기 전에 필요한 유희 시간” 정책 “15분” 이하로 설정

● Windows 2003, 2008, 2012, 2016, 2019, 2022

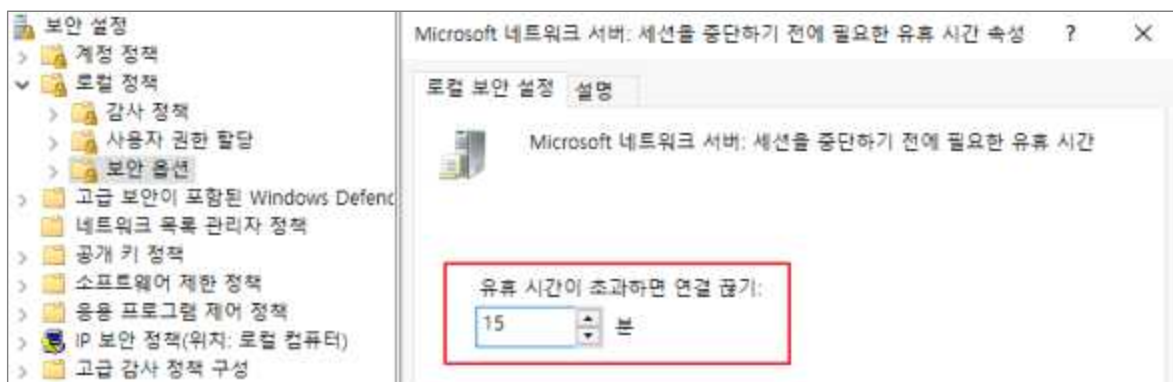
Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “Microsoft 네트워크 서버: 로그온 시간이 만료되면 클라이언트 연결 끊기” 정책 “사용” 설정

“Microsoft 네트워크 서버: 세션 연결을 중단하기 전에 필요한 유휴 시간” 정책 “15분” 이하로 설정



[로그온 시간이 만료되면 클라이언트 연결 끊기 “사용” 설정]



[세션을 중단하기 전에 필요한 유휴 시간 “15분” 설정]

02. Windows 서버

W-57 (하)	Windows 서버 > 5. 보안 관리
	로그온 시 경고 메시지 설정
개요	
점검 내용	로그온 시 경고 메시지 출력 여부 점검
점검 목적	로그온 시 경고 메시지를 설정하여 시스템에 로그인을 시도하는 사용자에게 관리자는 시스템의 불법적인 사용에 대하여 경고 창을 띄움으로써 경각심을 주기 위함
보안 위협	로그온 경고 메시지가 없는 경우 악의적인 사용자에게 관리자가 적절한 보안 수준으로 시스템을 보호하고 있으며, 공격자의 활동을 주시하고 있다는 생각을 상기시킬 수 없어 간접적인 공격 기회를 제공할 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 로그인 경고 메시지 제목 및 내용이 설정된 경우
	취약 : 로그인 경고 메시지 제목 및 내용이 설정되어 있지 않은 경우
조치 방법	로그인 메시지 제목 및 메시지 내용에 경고 문구 삽입
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT

Step 1) 시작 > 제어판 > 관리 도구 > 레지스트리 편집기

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\WindowsNT\CurrentVersion\Winlogon

Step 2) LegalNoticeCaption: 제목

Step 3) LegalNoticeText: 메시지 내용

※ 변경된 레지스트리 키의 내용은 시스템을 로그오프 한 후 반영됨

● Windows 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) 로그인 시도하는 사용자에게 대한 메시지 제목: 배너 제목 입력

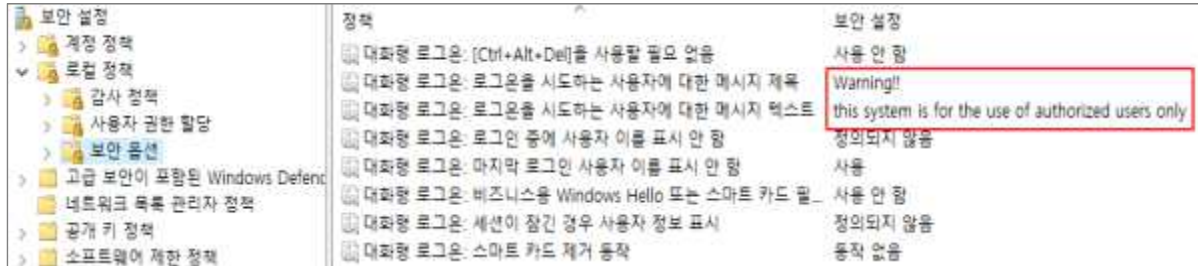
Step 3) 로그인 시도하는 사용자에게 대한 메시지 텍스트: 배너 내용 입력

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) 대화형 로그인: 로그인 시도하는 사용자에게 대한 메시지 제목: 배너 제목 입력

Step 3) 대화형 로그인: 로그인 시도하는 사용자에게 대한 메시지 텍스트: 배너 내용 입력



[로그인 시도 경고 메시지 설정]

02. Windows 서버

W-58 (중)	Windows 서버 > 5. 보안 관리
	사용자별 홈 디렉터리 권한 설정
개요	
점검 내용	사용자 홈 디렉터리 권한 적절성 점검
점검 목적	사용자 홈 디렉터리에 적절한 권한을 부여하여 비인가 사용자에게 의한 불필요한 정보 노출을 방지하기 위함
보안 위협	사용자 계정별 홈 디렉터리의 권한이 제한되어 있지 않으면 임의의 사용자나 다른 사용자의 홈 디렉터리에 악의적인 목적으로 접근할 수 있으며, 접근 후 의도 또는, 의도하지 않은 행위로 시스템에 악영향을 미칠 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 홈 디렉터리에 Everyone 권한이 없는 경우 (All Users, Default User 디렉터리 제외)
	취약 : 홈 디렉터리에 Everyone 권한이 있는 경우
조치 방법	Everyone 권한 제거
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT

Step 1) Windows NT: C:\WinNT\Profiles\사용자 홈 디렉터리 > 등록 정보 > 보안

Step 2) Everyone 권한 제거(All Users, Default User 디렉터리는 제외)

● Windows 2000, 2003

Step 1) C:\Documents and Settings\사용자 홈 디렉터리 > 속성 > 보안

Step 2) Everyone 권한 제거(All Users, Default User 디렉터리는 제외)

● Windows 2008

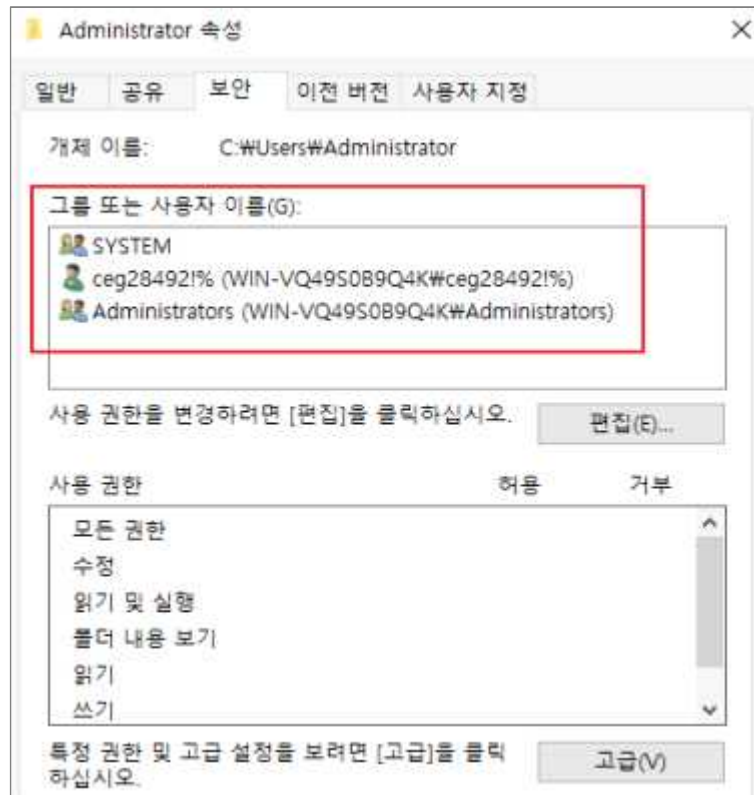
Step 1) C:\사용자<사용자 계정>

Step 2) 해당 사용자에게 대한 권한 외 일반 계정 삭제

- Windows 2012, 2016, 2019, 2022

Step 1) C:\사용자\<사용자 계정>

Step 2) 해당 사용자에게 대한 권한 외 일반 계정 삭제



[사용자 권한 설정 확인]

02. Windows 서버

W-59 (중)	Windows 서버 > 5. 보안 관리
	LAN Manager 인증 수준
개요	
점검 내용	LAN Manager 인증 수준 적절성 점검
점검 목적	LAN Manager 인증 수준 설정을 통해 네트워크 로그인에 사용할 Challenge/ Response 인증 프로토콜을 결정하며, 안전한 인증 절차를 적용하기 위함
보안 위협	안전하지 않은 LAN Manager 인증 수준을 사용하는 경우 인증 트래픽을 가로채기를 통해 악의적인 계정 정보 노출 위험이 존재함
참고	※ LAN Manager는 네트워크를 통한 파일 및 프린터 공유 등과 같은 작업 시 인증을 담당. NTLMv2는 Windows 2000, 2003, XP 이상에서 지원되며, Windows 98, NT 버전과 통신하면 패치를 설치해야 함
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : "LAN Manager 인증 수준" 정책에 "NTLMv2 응답만 보냄"이 설정되어 있는 경우
	취약 : "LAN Manager 인증 수준" 정책에 "LM" 및 "NTLM"인증이 설정되어 있는 경우
조치 방법	- Windows 2000 : LAN Manager 인증 7수준 - > NTLMv2 응답만 보내기 - Windows 2003, 2008, 2012, 2016, 2019 : 네트워크 보안: LAN Manager 인증 수준 - > NTLMv2 응답만 보내기
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) "LAN Manager 인증 수준" 정책에 "NTLMv2 응답만 보내기" 설정

- Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) “네트워크 보안: LAN Manager 인증 수준” 정책에 NTLMv2 응답만 보내기” 설정



[LAN Manager 인증 수준 설정]

02. Windows 서버

W-60 (중)	Windows 서버 > 5. 보안 관리
	보안 채널 데이터 디지털 암호화 또는 서명
개요	
점검 내용	‘보안 채널 데이터 디지털 암호화 또는 서명’ 정책 적절성 점검
점검 목적	해당 정책을 활성화하여 보안 채널의 서명 또는 암호화를 협상하지 않는 한 보안 채널을 확립하지 않기 위함
보안 위협	보안 채널이 암호화되지 않으면 인증 트래픽 끼어들기 공격, 반복 공격 및 기타 유형의 네트워크 공격 등의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 아래 3가지 정책 모두 "사용"으로 되어있는 경우 • 도메인 구성원: 보안 채널 데이터를 디지털 암호화 또는 서명(항상) • 도메인 구성원: 보안 채널 데이터를 디지털 암호화(가능한 경우) • 도메인 구성원: 보안 채널 데이터 디지털 서명(가능한 경우)
	취약 : 아래 3가지 정책 중 일부가 "사용 안 함"으로 되어있는 경우 • 도메인 구성원: 보안 채널 데이터를 디지털 암호화 또는 서명(항상) • 도메인 구성원: 보안 채널 데이터를 디지털 암호화(가능한 경우) • 도메인 구성원: 보안 채널 데이터 디지털 서명(가능한 경우)
조치 방법	보안 채널 데이터를 디지털 암호화·서명 관련 3개 정책 → 사용
조치 시 영향	도메인 구성원만 해당하며, Windows 98/NT와 파일 및 프린터 공유 등의 작업하지 않는 경우 일반적으로 영향 없음

점검 및 조치 사례

● Windows NT, 2000

Step 1) 시작 > 실행 > SECPOL.MSC > 로컬 정책 > 보안 옵션

Step 2) 아래 3가지 정책을 모두 "사용"으로 설정

- 도메인 구성원: 보안 채널 데이터를 디지털 암호화 또는 서명 (항상)
- 도메인 구성원: 보안 채널 데이터 디지털 서명 (가능한 경우)
- 도메인 구성원: 보안 채널 데이터를 디지털 암호화 (가능한 경우)

● Windows 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 로컬 정책 > 보안 옵션

Step 2) 아래 3가지 정책을 모두 "사용"으로 설정

- 도메인 구성원: 보안 채널 데이터를 디지털 암호화 또는 서명 (항상)
- 도메인 구성원: 보안 채널 데이터 디지털 서명 (가능한 경우)
- 도메인 구성원: 보안 채널 데이터를 디지털 암호화 (가능한 경우)

보안 설정	정책	보안 설정
> 계정 정책	대화형 로그인: 컴퓨터 비활성 제한	정의되지 않음
> 로컬 정책	도메인 구성원: 고급 세션 키 요청(Windows 2000 이상)	사용
> 감사 정책	도메인 구성원: 보안 채널 데이터 디지털 서명(가능한 경우)	사용
> 사용자 권한 할당	도메인 구성원: 보안 채널 데이터를 디지털 암호화 또는 서명(항상)	사용
> 보안 옵션	도메인 구성원: 보안 채널 데이터를 디지털 암호화(가능한 경우)	사용
> 고급 보안이 포함된 Windows Defenc	도메인 구성원: 컴퓨터 계정 암호 변경 사항 사용 안 함	사용 안 함
> 네트워크 목록 관리자 정책	도메인 구성원: 컴퓨터 계정 암호의 최대 사용 기간	30 일
> 공개 키 정책		

[보안 채널 데이터 설정 적용]

02. Windows 서버

W-61 (중)	Windows 서버 > 5. 보안 관리
	파일 및 디렉토리 보호
개요	
점검 내용	NTFS 파일 시스템 사용 여부 점검
점검 목적	FAT 파일 시스템에 비해 더 강화된 보안 기능을 제공하는 파일 시스템을 사용하기 위함 (파일과 디렉터리에 소유권과 사용 권한 설정이 가능하고 ACL(접근통제 목록)을 제공)
보안 위협	FAT 파일 시스템 사용 시 사용자별 접근통제를 적용할 수 없어 중요 정보에 대한 책임 추적성 확보가 어려운 위험이 존재함
참고	※ 기존에 FAT 파일 시스템을 사용하다가 NTFS로 변환하기 위해서는 convert.exe 명령을 사용할 수 있지만, FAT 파일 시스템으로 운영 중 변환해야 하는 경우 Default ACL이 적용되지 않으므로 가능한 초기 설치 시 NTFS 파일 시스템을 선택하는 것을 권장함 ※ 최근 운영체제 버전에서는 FAT32 파일 시스템을 지원하지 않으나 기존 FAT32에서 NTFS 변환 가능 ※ NTFS, FAT 파일 시스템 비교: FAT32에는 NTFS가 제공하는 보안 기능이 없으므로 컴퓨터에 FAT32 파티션 또는, 볼륨이 있는 경우 컴퓨터에 액세스 가능한 모든 사용자가 파일을 읽을 수 있으며 FAT32에는 크기 제한이 있음.
점검 대상 및 판단 기준	
대상	Windows NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : NTFS 파일 시스템을 사용하는 경우
	취약 : FAT 파일 시스템을 사용하는 경우
조치 방법	FAT 파일 시스템을 사용 시 가능한 NTFS 파일 시스템 변환 설정
조치 시 영향	파일 시스템을 변환할 경우 기존 파일 시스템에 영향을 줄 수 있음

점검 및 조치 사례

● Windows NTM, 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 실행 > CMD > fsutil fsinfo volumeinfo (해당 드라이브)

Step 2) FAT 파일 시스템 사용 시 아래 명령으로 NTFS 변환

시작 > 실행 > CMD > convert 드라이브명: /fs:ntfs

(예) convert F: /fs/ntfs라고 입력 시 F 드라이브는 NTFS 형식으로 변환됨

W-62 (중)	Windows 서버 > 5. 보안 관리
	시작 프로그램 목록 분석
개요	
점검 내용	시작 프로그램 목록 내 불필요한 항목 존재 여부 점검
점검 목적	불필요한 시작 프로그램을 삭제하거나 비활성화하여 악의적인 공격을 차단하기 위함
보안 위협	Windows 시작 시 너무 많은 시작 프로그램이 동시에 실행되면 속도가 저하되는 문제가 발생하며, 공격자가 심어놓은 악성 프로그램이나 해킹 도구가 실행되어 시스템에 피해를 줄 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : 시작 프로그램 목록을 정기적으로 검사하고 불필요한 서비스를 비활성화한 경우
	취약 : 시작 프로그램 목록을 정기적으로 검사하지 않고, 부팅 시 불필요한 서비스도 실행되고 있는 경우
조치 방법	시작 프로그램 목록의 정기적인 검사 실시 및 불필요한 서비스 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2000, 2003, 2008

Step 1) 시작 > 검색 > msconfig

Step 2) 시작 프로그램 탭 클릭 > 시작 프로그램 목록 중 불필요하거나 의심스러운 항목 체크 표시 해제

● Windows 2012, 2016, 2019, 2022

Step 1) Windows 2012 서버 이후 버전의 경우 시작 프로그램 목록 편집이 불가능하며 별도의 편집이나 등록을 위해서는 배치파일이나 레지스트리 값 추가를 이용해서 개인화를 통해 사용할 수 있으나 보안상 권장하지 않음

W-63 (중)	Windows 서버 > 5. 보안 관리
	도메인 컨트롤러-사용자의 시간 동기화
개요	
점검 내용	도메인 컨트롤러와 사용자의 시간 동기화 여부 점검
점검 목적	이 설정은 Kerberos가 클라이언트 시계의 시간과 서버 시계의 시간 사이에서 허용되는 최대 시간 차이(분)를 결정하는 동시에 두 시계의 동기를 고려하여, 재전송 공격을 방지하기 위함
보안 위협	Replay Attack 이란 프로토콜 상 메시지를 복사한 후 재전송함으로써 승인된 사용자로 오인하게 만들어 내부 침입 및 정보 유출 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Windows 2012, 2016, 2019, 2022
판단 기준	양호 : 컴퓨터 시계 동기화 최대 허용 오차값이 5분 이하인 경우
	취약 : 컴퓨터 시계 동기화 최대 허용 오차값이 5분 초과인 경우
조치 방법	Kerberos 사용 시 컴퓨터 시계 동기화 최대 허용 오차값 5분 이하로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > 관리 도구 > 로컬 보안 정책 > 계정 정책 > Kerberos 정책

컴퓨터 시계 동기화 최대 허용 오차 5분으로 설정



[컴퓨터 시계 동기화 최대 허용 오차]

W-64 (중)	Windows 서버 > 5. 보안 관리
	윈도우 방화벽 설정
개요	
점검 내용	시스템의 방화벽 기능이 활성화되어 있는지 점검
점검 목적	방화벽 기능 활성화 여부를 점검하여 시스템에서 외부망의 비인가 접근 및 외부망으로 통신을 시도하는 프로그램에 대해 통제하고 있는지 확인하기 위함
보안 위협	방화벽 기능이 비활성화되어 있으면, 외부 및 내부의 접근통제가 되지 않아 유해 정보가 유입되거나 시스템 사용자의 파일이나 폴더가 외부로 유출될 위험이 존재함
참고	※ 방화벽 : 인터넷 또는 외부 네트워크에서 유입되는 트래픽을 통제하는 솔루션으로써 외부의 불법 침입으로부터 내부의 정보 자산을 보호하고 외부로부터 유해 정보 유입을 차단하기 위한 정책과 이를 지원하는 하드웨어와 소프트웨어를 총칭함
점검 대상 및 판단 기준	
대상	Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022
판단 기준	양호 : Windows 방화벽 “사용”으로 설정된 경우
	취약 : Windows 방화벽 “사용 안 함”으로 설정된 경우
조치 방법	Windows 방화벽 “사용”으로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Windows 2000, 2003, 2008, 2012, 2016, 2019, 2022

Step 1) 시작 > 제어판 > Windows Defender 방화벽 > Windows 방화벽 설정 또는 해제

(또는 시작 > 실행 > “firewall.cpl” 입력)

Step 2) Windows Defender 방화벽 “사용” 설정



[방화벽 “사용” 설정]